Daffodil International University

Department of Software Engineering

Software Requirements Specification

TrustBazaar: A Verified Peer-to-Peer Auction and Marketplace Platform for Used Goods

S. M. Nihal Ahmed (232-35-002)

Afrim Hossen Khan (232-35-076)

Sabikun Nahar Sinthia (232-35-475)

BSc in Software Engineering, Capstone Project

Document status	Draft for review
Version	2.0
Date	14 October 2026
Standard followed	IEEE Std 830-1998 (structure), informed by ISO/IEC/IEEE 29148:2018
Companion documents	Project Proposal (revised); Supplementary Market Analysis

Revision History

Version	Date	Change
1.0	September 2026	Initial specification: 91 functional and 20 non-functional requirements in 13 feature areas.
1.1	October 2026	Game-account escrow added (FR-92 to FR-103, NFR-21 to NFR-23); disputes raised to Must Have; technology constraints aligned with the repository.
2.0	14 October 2026	Full review. Flaws in v1.1 corrected (Appendix C); security requirements chapter added; per-requirement priority and verification method; area-based identifiers (mapping in Appendix D); configurable parameters collected in one table; architecture, sequence diagrams and entity fields removed, to be specified in the System Design Document.

Contents

1 Introduction **5**

1.1 Purpose . . . 5
1.2 Document Conventions . . . 5
1.3 Intended Audience and Reading Suggestions . . . 6
1.4 Product Scope . . . 6
1.5 Definitions, Acronyms and Abbreviations . . . 7
1.6 References . . . 8
1.7 Overview of this Document . . . 8

2 Overall Description **9**

2.1 Product Perspective . . . 9
2.2 Product Functions . . . 9
2.3 User Classes and Characteristics . . . 9
2.4 Operating Environment . . . 10
2.5 Design and Implementation Constraints . . . 10
2.6 User Documentation . . . 11
2.7 Assumptions and Dependencies . . . 11
2.8 Release Scope . . . 11

3 External Interface Requirements **13**

3.1 User Interfaces . . . 13
3.2 Hardware Interfaces . . . 14
3.3 Software Interfaces . . . 14
3.4 Communications Interfaces . . . 14

4 Functional Requirements **16**

4.1 Account Registration and Authentication (ACC) . . . 16
4.2 Identity Verification (KYC) . . . 17
4.3 Listing Creation and Management (LST) . . . 18
4.4 Search and Discovery (SRC) . . . 19
4.5 Auction Engine (AUC) . . . 19

4.6 Fixed-Price Purchase (FIX) . . . 21
4.7 Payment and Escrow Settlement (PAY) . . . 21
4.8 Delivery and Handover of Physical Items (DLV) . . . 23
4.9 Game-Account Escrow (GAM) . . . 25
4.10 Real-Time Chat (CHT) . . . 27
4.11 Ratings, Reviews and Trust Signals (REV) . . . 28
4.12 Dispute Resolution (DSP) . . . 28
4.13 Notifications (NTF) . . . 29
4.14 Monetization (MON) . . . 30
4.15 Trust and Safety (TNS) . . . 31
4.16 Operator and Administrator Functions (OPS) . . . 31
4.17 Privacy and Data-Subject Rights (PRV) . . . 32

5 Security Requirements 34
5.1 Security Objectives . . . 34
5.2 Threats Considered . . . 35
5.3 General . . . 35
5.4 Authentication (SEC-AUTH) . . . 35
5.5 Session Management (SEC-SES) . . . 36
5.6 Access Control (SEC-ACC) . . . 37
5.7 Data Protection and Cryptography (SEC-DAT) . . . 38
5.8 Game-Account Credential Security (SEC-GAM) . . . 38
5.9 Input, Output and File Handling (SEC-INP) . . . 39
5.10 Browser and API Hardening (SEC-WEB) . . . 39
5.11 Payment Security (SEC-PAY) . . . 40
5.12 Abuse Prevention (SEC-ABU) . . . 40
5.13 Logging, Audit and Monitoring (SEC-LOG) . . . 41
5.14 Secure Development and Supply Chain (SEC-SDL) . . . 41
5.15 Deployment and Infrastructure (SEC-INF) . . . 42
5.16 Vulnerability and Incident Management (SEC-IRM) . . . 42

6 Other Non-Functional Requirements 43
6.1 Performance (PERF) . . . 43
6.2 Reliability and Availability (REL) . . . 43
6.3 Usability and Accessibility (USE) . . . 44
6.4 Maintainability and Portability (MNT) . . . 44
6.5 Scalability (SCL) . . . 45
6.6 Observability (OBS) . . . 45
6.7 Legal and Regulatory Compliance (CMP) . . . 46

7 Data Requirements **47**
7.1 Information the System Shall Keep 47
7.2 Data Classification 48
7.3 Retention 48

8 Business Rules and Configurable Parameters **49**
8.1 Configurable Parameters 49
8.2 Settlement Example 51
8.3 Revenue Streams 51

A Acceptance Criteria **52**

B Traceability **53**
B.1 Proposal Objectives to Requirements 53
B.2 Supplementary Report Loopholes to Requirements 53

C Corrections to Version 1.1 **55**

D Mapping of Version 1.1 Identifiers **58**

E Open Issues **60**

1 Introduction

1.1 Purpose

This Software Requirements Specification (SRS) defines what **TrustBazaar** must do and the qualities it must have. TrustBazaar is a web-based, peer-to-peer marketplace in which identity-verified individuals in Bangladesh sell used goods and game accounts to one another, either at a fixed price or through a time-boxed auction. Every payment is held in escrow until the buyer has received what they paid for, delivery is arranged either as a safe in-person handover or through a courier, and disputes are decided while the money is still held.

The SRS is the single reference for the system's scope and required behaviour during design, implementation, testing and academic evaluation. It states *what* the system shall do, not *how* it is built: the architecture, component design, data schema and sequence diagrams belong to the System Design Document (SDD), which will be written after this specification is agreed. The reasons behind the requirements, drawn from a study of Bikroy, Facebook Marketplace and Daraz, are given in the Supplementary Market Analysis ("the Supplementary Report"), and the project plan is given in the revised Project Proposal.

1.2 Document Conventions

Requirement identifiers. Each requirement has a stable identifier made of a type and an area code, for example **FR-PAY-07** (functional, payment and escrow), **SEC-AUTH-03** (security, authentication) or **NFR-PERF-02** (other non-functional, performance). Identifiers are never reused; a withdrawn requirement keeps its identifier and is marked as withdrawn. Version 1.1 used a single running number (FR-1 to FR-103, NFR-1 to NFR-23); Appendix D maps every old number to its new identifier.

Keywords. **shall** marks a mandatory requirement; **should** marks a recommended one whose omission must be justified; **may** marks an option. Each requirement states one testable behaviour.

Priority (Pri column). MoSCoW: **M** Must Have (required for the capstone deliverable), **S** Should Have (planned; may be descoped with the reason documented), **C** Could Have (built if time allows), **W** Won't Have in this release (recorded so the boundary is explicit). A requirement marked **(prod)** applies to a production deployment only; in the academic deliverable it is met by documentation or by a sandbox equivalent, as the requirement states.

Verification method (Ver column). **T** Test (automated or scripted), **D** Demonstration, **I** Inspection of code, configuration or documents, **A** Analysis (calculation, review or measurement report).

Configurable parameters. Every time limit, threshold and rate used by a requirement is a named parameter, written **CP-nn**, with its default value listed in Table 8.1 (Chapter 8). Requirements refer to the parameter, not to a hard-coded number.

Money and time. Amounts are in Bangladeshi Taka (BDT). Internally, amounts are integers in poisha (1 BDT = 100 poisha), so no amount is ever stored or calculated in floating point. Times are recorded in UTC and shown to users in Bangladesh Standard Time (Asia/Dhaka, UTC+06:00).

1.3 Intended Audience and Reading Suggestions

- **Course supervisor and evaluation panel**: Chapters 1 and 2 for scope; Appendix A for the acceptance criteria; Appendix B for how each requirement traces to the proposal and the Supplementary Report.
- **Development team**: Chapter 4 (functional requirements), Chapter 5 (security) and Chapter 8 (parameters and business rules) are the implementation references. Each functional area maps to one backend module.
- **Testers and reviewers**: the Ver column of each table, Chapter 6 (measurable quality targets) and Appendix A.

1.4 Product Scope

TrustBazaar is a single responsive web application, not a native mobile app, for individual-to-individual resale within Bangladesh. It exists to solve five connected problems that informal channels leave open (Supplementary Report, Sections 3–5):

1. **Trust between strangers**: every person who lists, bids, buys or receives money is identity-verified (KYC), and one person can hold only one verified account.
2. **Fair price discovery**: a server-timed auction with proxy bidding, a reserve price and anti-sniping runs alongside fixed-price sale and stays correct under simultaneous bidding.
3. **Protected payment**: every payment is held in escrow and leaves it only by buyer confirmation after handover, by a timeout counted from a recorded handover, or by an operator's dispute decision.
4. **Safe fulfilment**: no cash changes hands at a meeting; the buyer either collects the item at a suggested safe public meetup point or receives it by courier at a system-quoted fare.
5. **Safe game-account trading**: ownership is proven before listing, login details are encrypted so that only the buyer can read them, and the payment is held through a protection period after the buyer takes the account over.

Chat, ratings, notifications and monetization support this transaction lifecycle; they are not separate products.

Out of scope

- Sale of new or branded retail stock by businesses; TrustBazaar is not a general e-commerce storefront.
- A general administration or management console. The internal roles (Platform Operator and Administrator, Section 2.3) can perform only the specific actions listed in Section 4.16.

- Integration with game publishers. TrustBazaar cannot prevent a publisher from acting against an account that has changed hands; this risk is disclosed to the buyer before payment (FR-GAM-05).
- Real money movement and live courier bookings in the academic deliverable. Sandbox and test-mode integrations are used, and every substitution is disclosed rather than presented as live.
- Native mobile apps, cash on delivery, cryptocurrency payments, international shipping and sales outside Bangladesh.

1.5 Definitions, Acronyms and Abbreviations

Administrator	Internal role that manages operator accounts, configurable parameters and feature switches; has no access to case data (Section 2.3).
Auction	Listing sold to the highest valid bid at a server-determined end time.
Anti-sniping	Automatic extension of an auction's end time when a valid bid arrives close to it.
ASVS	OWASP Application Security Verification Standard.
Blind index	Keyed hash (HMAC) of a sensitive value, used to test equality (for example, whether an NID is already registered) without storing the value in readable form.
Ciphertext	Encrypted data; here, game-account login details encrypted for the buyer.
CP-nn	Configurable parameter, defined in Table 8.1.
Delivery event	The recorded moment from which post-delivery deadlines are counted: the handover-code entry for a meetup (FR-DLV-06), the provider's `delivered` status for a courier order (FR-DLV-10), or, for a game account, completion of the takeover (FR-GAM-15).
Dispute	A buyer's formal claim against an order, made while the payment is held, decided by an operator.
Escrow	Funds collected from the buyer and held, not payable to the seller, until a release condition in FR-PAY-07 is met.
Four-eyes approval	An action that takes effect only after a second, different authorised person approves it.
Handover code	One-time code shown only to the buyer, given to the seller after the buyer has inspected the item, which records the handover.
KYC	Know Your Customer: verifying a person's identity from a government-issued document and a live selfie.
Ledger	Append-only, itemised record of how a payment was divided among seller, courier, platform and any refund.
MFA	Multi-factor authentication.
MFS	Mobile Financial Service, such as bKash or Nagad.
NID	Bangladesh National Identity Card.
Operator	Internal role that reviews KYC submissions, ownership proofs, reports and disputes (Section 2.3).
OTP	One-time password sent by SMS or generated by an authenticator app.
PDPO	Personal Data Protection Ordinance, 2025 (Bangladesh).
Protection period	Time after a game-account takeover (CP-24) during which the payment stays in escrow so that recovery of the account by the seller can still be refunded.
Proxy bid	A private maximum set by a bidder; the system bids on the bidder's behalf up to that maximum.
Reserve price	A hidden minimum below which an auction does not sell.
Sealed credentials	Game-account login details encrypted in the seller's browser with a key that only the buyer's browser holds.
Step-up authentication	A fresh OTP or second-factor check required before a sensitive action even within a valid session.

Takeover	The buyer securing a purchased game account by changing its password, recovery e-mail and phone, linked logins and two-step verification.
TOTP	Time-based one-time password (RFC 6238), generated by an authenticator app.
Verified user	A user whose KYC status is `verified`.

1.6 References

[R1] IEEE Std 830-1998, *IEEE Recommended Practice for Software Requirements Specifications*.

[R2] ISO/IEC/IEEE 29148:2018, *Systems and software engineering – Life cycle processes – Requirements engineering*.

[R3] OWASP, *Application Security Verification Standard 5.0.0*, May 2025.

[R4] OWASP, *Top 10:2021*.

[R5] NIST SP 800-63B-4, *Digital Identity Guidelines: Authentication and Authenticator Management*, August 2025.

[R6] PCI Security Standards Council, *PCI DSS v4.0.1*, June 2024, and FAQ 1588 on SAQ A eligibility, February 2025.

[R7] W3C, *Web Content Accessibility Guidelines (WCAG) 2.2*, October 2023.

[R8] W3C, *Web Cryptography API* (Recommendation).

[R9] IETF RFC 6238 (TOTP); RFC 6797 (HTTP Strict Transport Security); RFC 9116 (`security.txt`).

[R10] Government of Bangladesh, *Personal Data Protection Ordinance, 2025* (Ordinance No. 61 of 2025), gazetted 6 November 2025.

[R11] Government of Bangladesh, *Cyber Security Ordinance, 2025* (Ordinance No. 25 of 2025), gazetted 21 May 2025.

[R12] Bangladesh Bank, instructions on escrow service for digital commerce (June 2021), and Ministry of Commerce, *Digital Commerce Operational Guidelines 2021*, as summarised in the Supplementary Report.

[R13] bKash Tokenized Checkout, Nagad Merchant and Stripe API documentation (sandbox and test modes, webhook verification).

[R14] Published rate cards of Pathao Courier, Steadfast Courier, RedX and Sundarban Courier Service.

[R15] S. M. N. Ahmed, A. H. Khan and S. N. Sinthia, *Trust in Bangladesh's Second-Hand Online Market: A Market Analysis of Bikroy.com and Its Alternatives*, supplementary report to the project proposal, October 2026.

[R16] TrustBazaar team, *Project Proposal (revised)*, October 2026.

[R17] TrustBazaar repository, `https://github.com/nihal4/trustbazaar`.

1.7 Overview of this Document

Chapter 2 describes the product's context, users, environment, constraints and assumptions. Chapter 3 specifies external interfaces. Chapter 4 specifies functional requirements by area, following the transaction lifecycle. Chapter 5 specifies security requirements, and Chapter 6 the other quality attributes. Chapter 7 states what information the system must keep, how it is classified and how long it is retained. Chapter 8 lists the configurable parameters and business rules. The appendices give the acceptance criteria, traceability, the corrections made to v1.1, the identifier mapping and the open issues.

2 Overall Description

2.1 Product Perspective

TrustBazaar is a new, self-contained system. It replaces no existing system; it competes with Bikroy, Facebook Marketplace groups and informal "admin deals", which connect buyers and sellers but leave payment, handover and disputes to the parties (Supplementary Report, Sections 3 and 5). The system interacts with the following external parties; how it is divided internally is a design matter for the SDD.

- **Users** through a web browser on a phone or computer.
- **Internal staff** (operators and administrators) through restricted views of the same web application.
- **Payment providers**: bKash, Nagad and Stripe, for collecting payments, refunds and seller payouts.
- **Courier providers**: Pathao or Steadfast through their sandbox APIs, or a documented mock courier service.
- **Messaging providers**: an SMS gateway for OTPs and security alerts, and an e-mail service for transactional messages.
- **Browser platform services**: camera access for the KYC selfie, geolocation for approximate location, and the Web Cryptography API for game-account credentials.

2.2 Product Functions

At the highest level, the system shall allow users to:

- register, verify their phone and e-mail, sign in securely and complete KYC verification;
- list a physical item or a game account for fixed-price sale or auction, and browse, search and filter listings;
- bid in a server-timed auction or buy a fixed-price item, and chat with the counterparty about a listing;
- pay by bKash, Nagad or card into escrow, and receive the item at a safe meetup point or by courier, or receive a game account through a sealed handover and guided takeover;
- confirm receipt to release payment, or open a dispute while the payment is still held;
- receive payouts to a verified payout account, rate the counterparty, and report fraud;
- for sellers, optionally feature a listing or subscribe to the Pro Seller tier.

Internal staff can review KYC submissions, ownership proofs, reports and disputes, and manage configuration, each within the limits of Section 4.16.

2.3 User Classes and Characteristics

Guest	Not signed in. May browse and search active listings and view public profiles. Cannot chat, bid, buy or list.
Registered user	Account with verified phone number but KYC not yet `verified` (statuses `unsubmitted`, `pending_review`, `rejected` or `revoked`). May browse, save searches and chat. Cannot list, bid, buy or receive payouts.
Verified user	KYC status `verified`, aged 18 or over. May act as buyer and seller of physical items and game accounts. The default class for transacting users.
Pro Seller	Verified user with an active paid subscription: lower commission, higher listing limit and a sales analytics view (Could Have).
Platform Operator	Internal staff. Works the KYC, ownership-proof, report, flagged-activity and dispute queues. Can perform only the actions in FR-OPS-02; cannot change configuration or manage staff accounts. MFA is mandatory.
Administrator	Internal staff. Manages operator accounts, configurable parameters and feature switches. Cannot view KYC documents, chats or dispute evidence and cannot decide cases. MFA is mandatory.
External providers	Payment, courier and messaging providers. Not users of the interface; they interact through authenticated APIs and webhooks.

Users are assumed to be familiar with smartphones and mobile financial services, but not with auctions or escrow; the interface must explain both in plain language (NFR-USE-01, NFR-USE-07). Many users will reach the site on mid-range Android phones over mobile data.

2.4 Operating Environment

- **Client**: current versions of Chrome, Firefox, Safari and Edge, on Android, iOS and desktop, with WebSocket, camera (Media Capture) and Web Cryptography API support. Minimum supported viewport width: 360 CSS pixels.
- **Server**: Linux containers run with Docker Compose: PostgreSQL 15, Redis 7, the backend (Node.js 20, NestJS 10, TypeScript 5, with its Socket.IO 4 real-time gateway) and the web client (React 18, React Router 6, built with Vite).
- **Network**: all traffic over HTTPS and secure WebSockets; the system must remain usable on 4G mobile connections typical in Bangladesh.

2.5 Design and Implementation Constraints

C-1 The technology stack is fixed by the project repository [R17]: TypeScript on Node.js 20 with NestJS 10, PostgreSQL 15 accessed through TypeORM, Redis 7 accessed through ioredis, Socket.IO 4, React 18, Docker Compose, Jest, ESLint and GitHub Actions. A change requires agreement of the whole team and an update to this SRS.

C-2 Payment integrations shall use official sandbox or test-mode credentials only; no real financial transaction shall be processed in the academic deliverable.

C-3 Courier integration shall use a real courier's sandbox API where one is available; otherwise a mock courier that reproduces realistic fares and status updates shall be used, and the substitution shall be labelled in the user interface and documentation.

C-4 No custom cryptographic algorithm or protocol shall be written. Only vetted library or platform implementations (Node.js `crypto`, the browser Web Cryptography API, established password-hashing libraries) shall be used.

C-5 The Operator and Administrator roles shall be limited to the actions listed in Section 4.16; no generic create, edit or delete access to listings, users or orders shall be provided, so that the system remains a marketplace and not a management system.

C-6 TrustBazaar shall not integrate with game publishers. Because most publishers prohibit account transfers (Supplementary Report, Section 5.2), the game-account feature shall be switchable off by configuration (FR-GAM-01).

C-7 **(prod)** In a production deployment, buyers' funds shall be held through a payment service provider or bank licensed by Bangladesh Bank for escrow or payment services, not in an account controlled solely by TrustBazaar. In the academic deliverable, escrow is simulated by internal state over sandbox payments.

C-8 **(prod)** Personal data classified as Restricted or Confidential (Section 7.2) shall be stored and processed in a manner compliant with the PDPO [R10], including any requirement to keep such data within Bangladesh.

2.6 User Documentation

The deliverables are this SRS, the System Design Document, a README with setup instructions for Docker Compose, a privacy notice and terms of use, and in-app help. In-app help shall cover at least: the KYC process; auction rules (minimum increment, proxy bidding, reserve price, anti-sniping); how escrow, the handover code and the release timeout work; how to open a dispute; and, for game accounts, the ownership proof, the takeover checklist, the protection period and the publisher-terms risk.

2.7 Assumptions and Dependencies

AS-1 Sandbox access to bKash and Nagad can be obtained. If it cannot, Stripe test mode alone is used and the limitation is documented (risk accepted in the proposal).

AS-2 Server clocks are synchronised by NTP; auction fairness and every deadline in this SRS depend on it.

AS-3 Courier fares are reasonable approximations of published rate cards, not certified live quotes, unless a live sandbox is available.

AS-4 An SMS gateway with a test mode, or a logged mock that is labelled as such, is available for OTP delivery.

AS-5 Users' browsers support the Web Cryptography API; a browser without it cannot take part in a game-account sale and is told so before purchase.

AS-6 The protection given to game-account credentials assumes that the code the server sends to browsers has not been tampered with. It protects against database and backup compromise and against operators; it does not protect against an attacker who can change the deployed application code. That residual risk is reduced by the change controls in Section 5.14.

AS-7 KYC verification by an operator from an NID image and a selfie raises the cost of fraud but does not make it impossible; fake NIDs exist (Supplementary Report, Section 5.2). The design relies on escrow and identity checks covering each other's gaps.

2.8 Release Scope

The capstone deliverable comprises all Must Have requirements. Should Have and Could Have requirements are descoped in the order given in the proposal (delivery automation, notifications beyond those required for security, featured listings, Pro Seller tier) if the schedule slips. Requirements marked W are deliberately excluded, including: a paid buyer-protection add-on (protection is the same for every buyer); cash on delivery; and automatic approval of KYC

without an operator.

3 External Interface Requirements

3.1 User Interfaces

These requirements state which views must exist and what each must let the user do; layout and visual design are specified in the SDD.

ID	Requirement	Pri	Ver
IF-UI-01	The web client shall provide: registration with phone and e-mail verification; sign-in, including second-factor entry; password reset; and a security settings view listing active sessions, with an option to end them.	M	D
IF-UI-02	The web client shall provide a KYC wizard covering document capture, live selfie capture and a status tracker, which shows the reason for any rejection.	M	D
IF-UI-03	The web client shall provide listing creation, browse and search with filters, and a listing detail view. The detail view shows either a Buy action or a live auction panel with current price, server-synchronised countdown, bid and proxy-bid inputs, a masked bid history and a link to the auction rules.	M	D
IF-UI-04	The web client shall provide a checkout view showing the item price, delivery fee and total as one amount, the fulfilment method, the payment method, and the platform's fee disclosure.	M	D
IF-UI-05	The web client shall provide an order view showing payment and escrow status in plain language, the fulfilment status, every deadline that applies with its date and time, the handover code (buyer only), and the actions available at that point (confirm receipt, open dispute, cancel).	M	D
IF-UI-06	For game-account orders, the web client shall provide: an ownership-proof screen for the seller; a credential-handover screen for the seller; and, for the buyer, a credential view and a takeover checklist with countdowns for the takeover window and the protection period.	M	D
IF-UI-07	The web client shall provide a per-listing chat panel showing the off-platform payment warning when FR-CHT-07 applies.	M	D
IF-UI-08	The web client shall provide a seller dashboard showing listings, orders, payout account and payout history, and, for Pro Sellers, sales analytics.	M	D
IF-UI-09	The web client shall provide, to operators only, queue views for KYC, ownership proofs, reports, flagged activity and disputes, and, to administrators only, views for staff accounts, parameters and feature switches (Section 4.16).	M	D

ID	Requirement (continued)	Pri	Ver
IF-UI-10	Every view that shows money, a deadline or an irreversible action shall state its consequence before the user confirms it (for example, "Releasing payment pays the seller now and ends your right to dispute this order").	M	I

3.2 Hardware Interfaces

No special hardware is required. The KYC selfie is captured with the device camera through the browser's Media Capture API; uploading an existing gallery image is not accepted for the selfie (FR-KYC-02).

3.3 Software Interfaces

ID	Requirement	Pri	Ver
IF-SW-01	**bKash** (Tokenized Checkout, sandbox): payment creation, execution, query and refund, and webhook or callback confirmation; the buyer enters the wallet PIN on bKash's own page only.	M	T
IF-SW-02	**Nagad** (Merchant API, sandbox): payment initiation, confirmation callback, verification query and refund.	S	T
IF-SW-03	**Stripe** (test mode): card payment through a Stripe-hosted page or Stripe-hosted fields, refunds and subscription billing, with webhook signature verification.	M	T
IF-SW-04	**Courier** (Pathao or Steadfast sandbox, or the mock courier): fare quotation, booking, cancellation and status webhooks.	S	T
IF-SW-05	**SMS gateway** (test mode or labelled mock): delivery of OTPs and security alerts only.	M	T
IF-SW-06	**E-mail service** (SMTP or provider API; development capture tool in the academic deliverable): e-mail verification links and transactional notices.	M	T
IF-SW-07	**Web Cryptography API** (browser): key-pair generation, encryption and decryption of game-account credentials (FR-GAM-07, FR-GAM-09). No private key or plaintext credential is ever sent to the server.	M	T
IF-SW-08	**Geolocation API** (browser) for approximate coordinates, with manual area selection as a fallback when permission is refused.	S	T
IF-SW-09	**PostgreSQL 15** as the system of record for all transactional data, and **Redis 7** for countdown coordination, locks, publish/subscribe and rate-limit counters. Redis shall never be the only copy of authoritative state (NFR-REL-01).	M	I
IF-SW-10	**Identity-check service** (pretrained document-quality or face-match model or API) for the advisory KYC pre-check (FR-KYC-11).	C	T

3.4 Communications Interfaces

ID	Requirement	Pri	Ver
IF-COM-01	All client–server traffic shall use HTTPS, and all real-time traffic shall use secure WebSockets (Socket.IO over `wss`), with the transport requirements of SEC-DAT-01.	M	T
IF-COM-02	Live auction updates, outbid notices, chat messages and in-app notifications shall be delivered over the authenticated WebSocket connection (SEC-SES-07); a client that loses the connection shall resynchronise the current state from the server on reconnecting.	M	T
IF-COM-03	Payment, courier and messaging provider callbacks shall be received only on dedicated HTTPS endpoints and accepted only after the checks in SEC-PAY-03 and SEC-PAY-04.	M	T
IF-COM-04	The backend shall expose its HTTP API under a versioned path (for example `/api/v1`) and document it in OpenAPI format (NFR-MNT-05).	M	I

4 Functional Requirements

The areas follow the transaction lifecycle: account and identity, listing and discovery, the two purchase paths, payment and escrow, fulfilment (physical items, then game accounts), then the supporting areas. Security behaviour that applies across areas is specified once in Chapter 5 and referenced here.

4.1 Account Registration and Authentication (ACC)

ID	Requirement	Pri	Ver
FR-ACC-01	The system shall allow a person to register with a Bangladeshi mobile number, an e-mail address, a display name and a password that satisfies SEC-AUTH-01 and SEC-AUTH-02.	M	T
FR-ACC-02	The system shall activate an account only after the mobile number has been verified by OTP (SEC-AUTH-09). It shall verify the e-mail address by a single-use link (CP-06) before the user's first purchase, listing or payout.	M	T
FR-ACC-03	The system shall not create a second account for a mobile number or e-mail address already linked to an account. The attempt shall be handled as in SEC-AUTH-06, so that it does not reveal which accounts exist.	M	T
FR-ACC-04	At registration the system shall require the person to confirm they are 18 or older and to accept the current terms of use and privacy notice. It shall record the version of each document accepted and the time.	M	T
FR-ACC-05	The system shall allow a registered user to sign in with mobile number or e-mail plus password, followed by a second factor where one is enabled (FR-ACC-06), and shall then establish a session as specified in Section 5.5.	M	T
FR-ACC-06	The system shall allow a user to enable an authenticator-app second factor (TOTP, RFC 6238), shall issue single-use recovery codes when it is enabled, and shall require a current second factor to disable it. MFA is mandatory for staff accounts (SEC-AUTH-07).	S	T
FR-ACC-07	The system shall allow a user to reset a forgotten password through a single-use link sent to the verified e-mail, or an OTP sent to the verified mobile number, under the rules in SEC-AUTH-10.	M	T
FR-ACC-08	The system shall allow a user to view their active sessions (device type, approximate location, last activity), end any one of them, and end all sessions except the current one.	M	T

ID	Requirement (continued)	Pri	Ver
FR-ACC-09	The system shall allow a user to change their mobile number or e-mail only after step-up authentication (SEC-AUTH-08) and verification of the new value. It shall notify the old value of the change.	M	T
FR-ACC-10	The system shall show other users only a user's display name, verification badge, rating summary, number of completed transactions, join month and approximate area (district). It shall never show another user's mobile number, e-mail address, NID details or exact location.	M	T
FR-ACC-11	The system shall allow a user to request closure of their account. Closure shall be refused while the user has an open order, an unpaid auction win, an open dispute or an unpaid balance owed to the platform. After closure the user's data shall be handled as in Table 7.2.	S	T

4.2 Identity Verification (KYC)

ID	Requirement	Pri	Ver
FR-KYC-01	The system shall require a registered user to submit, for KYC: images of the front and back of their NID (or the photo page of a passport); the document number, full name and date of birth as printed; and a live selfie.	M	T
FR-KYC-02	The system shall capture the selfie through the device camera in the browser and shall not accept an uploaded file in its place. It shall ask the user to perform one randomly chosen action (for example, turning the head or blinking) during capture, as a basic liveness check.	M	D
FR-KYC-03	The system shall reject, and refer to an operator, any submission whose date of birth shows the person is under 18.	M	T
FR-KYC-04	The system shall not allow one NID or passport number to belong to more than one account. A submission whose document number matches another account (in any status other than `unsubmitted`) or the NID blacklist (FR-TNS-06) shall be routed to an operator and shall not be approved automatically. The comparison shall use a blind index (SEC-DAT-03).	M	T
FR-KYC-05	The system shall track each user's KYC status as exactly one of `unsubmitted`, `pending_review`, `verified`, `rejected` or `revoked`, and shall record every status change with time, actor and reason.	M	T
FR-KYC-06	An operator shall reject a submission only with a reason code from a fixed list (for example: image unreadable, selfie does not match, document expired, details do not match image, underage, duplicate identity). The reason shall be shown to the user with guidance on how to fix it.	M	T
FR-KYC-07	The system shall allow only users whose KYC status is `verified` to create a listing, place a bid, start a purchase, register a payout account or receive a payout. This shall be enforced server-side on every such request, and users in `pending_review` shall be refused as well.	M	T
FR-KYC-08	The system shall display a Verified badge on the profile and listings of every user whose KYC status is `verified`, and shall remove it immediately if the status changes.	M	T

ID	Requirement (continued)	Pri	Ver
FR-KYC-09	The system shall allow a user whose submission was rejected to resubmit, up to CP-34.	M	T
FR-KYC-10	An operator may revoke a user's verification only with a recorded reason and four-eyes approval (FR-OPS-05). On revocation, the system shall hide the user's active listings and block new bids and purchases. Open orders shall continue to completion under the normal escrow rules.	M	T
FR-KYC-11	The system should run an automated pre-check on each submission (image legibility and cropping, plausibility of the selfie-to-photo match) using an existing model or API, and attach the result to the review as advisory information. The pre-check shall never approve a submission; it may only flag one for closer review.	C	T
FR-KYC-12	The system should present each new submission in the operator queue within one minute, and operators should decide it within CP-44. The user shall be shown the expected review time.	S	A

4.3 Listing Creation and Management (LST)

ID	Requirement	Pri	Ver
FR-LST-01	The system shall allow a verified user to create a listing with: title, description, category, item kind (`physical` or `game_account`) and sale format (`fixed_price` or `auction`). Item kind and sale format shall not be changeable after publication.	M	T
FR-LST-02	For a physical item, the system shall require a condition (new, like new, used, for parts) and at least two photos. The seller shall either mark one photo as showing defects or declare that the item has no visible defects; the declaration shall be shown on the listing.	M	T
FR-LST-03	For a physical item, the system shall require a weight class and a package-size class, for use by the courier fare model (FR-DLV-07).	S	T
FR-LST-04	For a fixed-price listing, the system shall require a price and an available quantity of at least 1.	M	T
FR-LST-05	For an auction listing, the system shall require a starting price and a duration chosen from CP-07. It shall accept an optional reserve price, which shall be at least the starting price. The quantity of an auction listing is always 1.	M	T
FR-LST-06	For a physical item, the system shall record the seller's approximate pickup location, taken from the listing or from the seller's saved area, for distance calculation. Only the district or area name shall be shown on the listing.	M	T
FR-LST-07	Before the first bid or order on a listing, the seller may edit its title, description and photos, and, for a fixed-price listing, its price and quantity. After the first bid or order, the seller may only add time-stamped clarifications, shown below the original description. An auction's starting price, reserve price and duration shall never be editable after publication.	M	T
FR-LST-08	The seller may cancel a fixed-price listing that has no order awaiting payment or fulfilment, or an auction that has no bids. An auction with at least one bid may be cancelled only by an operator, with a recorded reason, and all bidders shall be notified.	M	T

ID	Requirement (continued)	Pri	Ver
FR-LST-09	The system shall limit the number of active listings per seller to CP-28, with a higher limit for Pro Sellers.	M	T
FR-LST-10	The system shall maintain a list of prohibited item categories, including at least: weapons and ammunition; drugs and controlled medicines; alcohol and tobacco; stolen goods; counterfeit or replica goods; government-issued documents; SIM cards registered to another person; live animals; adult content; and accounts other than game accounts (for example social-media, banking or MFS accounts). The prohibited categories shall not be selectable when creating a listing.	M	T
FR-LST-11	The system should screen listing text against a maintained list of prohibited and high-risk keywords (in Bangla and English) and should hold a matching listing in `pending_review` for an operator, rather than publishing it.	S	T
FR-LST-12	The system shall give each listing exactly one status out of `draft`, `pending_review`, `active`, `sold`, `ended_unsold`, `cancelled` or `removed`. It shall record every status change with time, actor and reason.	M	T
FR-LST-13	The system may offer to draft a title and description from the uploaded photos using an existing vision-language model or API. The draft shall be shown to the seller for editing and shall never be published without the seller's explicit confirmation.	C	D

4.4 Search and Discovery (SRC)

ID	Requirement	Pri	Ver
FR-SRC-01	The system shall provide full-text search over listing titles and descriptions, matching both Bangla and English text.	M	T
FR-SRC-02	The system shall allow results to be filtered by category, item kind, sale format, price range, condition, and maximum distance from the searcher's location or chosen area.	M	T
FR-SRC-03	The system shall allow results to be sorted by newest, price ascending, price descending, distance and auctions ending soonest.	M	T
FR-SRC-04	Search results and listing pages shall include only `active` listings whose seller is currently `verified` and not suspended.	M	T
FR-SRC-05	Guests shall be able to browse and search. Distances shall be shown rounded to the nearest kilometre and shall never reveal a seller's exact coordinates.	M	T
FR-SRC-06	The system may show recommended listings based on category, price range and the user's own browsing and purchase history. Recommendations shall be labelled and shall never include featured placement that is not labelled as such (FR-MON-05).	C	D

4.5 Auction Engine (AUC)

ID	Requirement	Pri	Ver
FR-AUC-01	The server shall hold the authoritative end time of every auction. Countdowns shown by the client shall be derived from server time and treated as informational only.	M	T
FR-AUC-02	The system shall accept a bid only if all of the following hold: the bidder is `verified`, not suspended from bidding, and not the seller; the auction is `active`; the server receives the bid before the authoritative end time; and the amount is at least the starting price (first bid) or at least the current price plus the minimum increment CP-08.	M	T
FR-AUC-03	The system shall serialise bid processing per auction so that, however many bids arrive at the same moment, each is evaluated against the state left by the previous one, and two bids can never both be recorded as the highest.	M	T
FR-AUC-04	The system shall reject any bid received after the authoritative end time, even if the client sent it before its local countdown reached zero. Acceptance shall be decided by the time the server receives the bid.	M	T
FR-AUC-05	When a valid bid is accepted within the anti-sniping window CP-09 before the current end time, the system shall set the end time to the time the bid was received plus the extension in CP-09, and shall broadcast the new end time.	M	T
FR-AUC-06	The system shall allow a bidder to set a proxy maximum. Whenever that bidder is outbid, it shall automatically place the smallest bid that restores them as highest bidder, never exceeding their maximum.	M	T
FR-AUC-07	When two proxy maximums are equal, the one set earlier shall win. The current price shall be the lower of the winner's maximum and the second-highest maximum plus the minimum increment.	M	T
FR-AUC-08	The system shall never reveal a bidder's proxy maximum to anyone else, including the seller and operators, except to an operator investigating a fraud flag on that auction.	M	T
FR-AUC-09	If a reserve price is set and the highest bid at close is below it, the auction shall end as `ended_unsold` and no order shall be created. While the reserve has not been met, the listing shall say "reserve not met" without revealing the amount.	M	T
FR-AUC-10	Bids are binding and cannot be retracted by the bidder. An operator may void a bid only on evidence of fraud or account compromise, with a recorded reason. The system shall then recompute the auction state as if the bid had never been placed, and shall notify affected bidders.	M	T
FR-AUC-11	The system shall broadcast every change of current price, highest-bidder mask and end time to every client viewing the auction (NFR-PERF-03).	M	T
FR-AUC-12	The system shall notify a bidder in real time when they are outbid (FR-NTF-01).	M	T
FR-AUC-13	The bid history shall be public, showing amounts and times, with each bidder shown by a consistent mask per auction (for example "Bidder 3"). It shall not identify bidders to the seller, to other bidders or to the public.	M	T
FR-AUC-14	When an auction closes with a valid winning bid, the system shall create an order for the winner at the winning price and require payment within CP-10. It shall notify the winner and the seller.	M	T

ID	Requirement (continued)	Pri	Ver
FR-AUC-15	If the winner does not pay within CP-10, the system shall cancel that order and offer the item to the next-highest eligible bidder at that bidder's highest bid, to be accepted and paid within CP-11. If no eligible bidder accepts, the listing shall end as `ended_unsold`, and the seller may relist it.	M	T
FR-AUC-16	A winner who fails to pay shall receive a non-payment strike. On reaching CP-12 strikes, the user shall be suspended from bidding for the period in CP-12, and told why.	M	T
FR-AUC-17	The system shall rate-limit bid submissions per user per auction (CP-35). This shall not limit bids placed automatically by the proxy mechanism.	M	T
FR-AUC-18	The system should score bidding activity for patterns that suggest shill bidding or collusion (for example, many small bids from newly verified accounts, or accounts linked by device or payout account to the seller). It should place flagged auctions in the operator's flagged-activity queue without blocking any bid automatically.	S	T

4.6 Fixed-Price Purchase (FIX)

These requirements apply to physical items and game accounts sold at a fixed price.

ID	Requirement	Pri	Ver
FR-FIX-01	The system shall allow a verified buyer, other than the seller, to start a purchase of a fixed-price listing at the listed price, for a quantity not exceeding the quantity available.	M	T
FR-FIX-02	Starting a purchase shall reserve the quantity and create an order awaiting payment in one atomic operation. Concurrent requests shall never reserve more units than are available.	M	T
FR-FIX-03	If payment is not confirmed within the checkout hold CP-13, the system shall cancel the order and return the reserved quantity to the listing.	M	T
FR-FIX-04	When the available quantity reaches zero and no reservation remains open, the system shall mark the listing `sold` and remove it from search results. While reservations are still open it shall show the listing as "currently reserved".	M	T
FR-FIX-05	Under a burst of simultaneous purchase requests, every request shall receive a definite response (reserved, or not available) and none shall be silently dropped. The total reserved shall never exceed the quantity listed.	M	T

4.7 Payment and Escrow Settlement (PAY)

ID	Requirement	Pri	Ver
FR-PAY-01	The system shall accept payment by bKash, Nagad and card, using each provider's sandbox or test mode in the academic deliverable (C-2).	M	T

ID	Requirement (continued)	Pri	Ver
FR-PAY-02	The system shall treat a payment as confirmed only on a server-to-server confirmation from the provider (webhook, callback or verification query), never on the client's redirect or on any value sent by the browser.	M	T
FR-PAY-03	Before confirming a payment, the system shall verify that the provider reports a successful payment whose order reference, amount and currency exactly match the order. On any mismatch it shall not place funds in escrow, shall flag the payment for operator review and shall start a refund through the provider.	M	T
FR-PAY-04	The system shall process provider confirmations idempotently: a confirmation delivered more than once, or confirmed both by webhook and by query, shall have exactly one effect.	M	T
FR-PAY-05	On confirmed payment, the system shall place the full amount collected (item price plus any delivery fee) in escrow in state `held`. No part of it shall be payable to the seller until a release condition in FR-PAY-07 is met.	M	T
FR-PAY-06	The escrow of each order shall be in exactly one of the states `held`, `frozen_disputed`, `released`, `refunded` or `partially_refunded`, and shall change state only by a transition listed in Table 4.8. Any other transition shall be rejected and logged as a security event.	M	T
FR-PAY-07	Escrowed funds shall be released to the seller only by one of the following. (a) The buyer confirms receipt after the delivery event. (b) The auto-release timeout CP-19 expires after the delivery event, with no dispute open. (c) An operator decides a dispute in the seller's favour. (d) For game accounts only, the rule in FR-GAM-17 applies. The system shall not offer the buyer a "confirm receipt" action before the delivery event.	M	T
FR-PAY-08	The auto-release timeout shall be counted from the delivery event, never from payment. If the required fulfilment step is not recorded by its deadline, the system shall cancel the order and refund the buyer in full, unless a dispute is open. The steps and deadlines are: the handover for a meetup (CP-15); courier pickup (CP-16); and credential delivery for a game account (CP-22).	M	T
FR-PAY-09	Before the delivery event, the buyer may request cancellation and the seller may accept it, and the seller may cancel unilaterally; either cancellation shall refund the buyer in full. A unilateral seller cancellation after payment shall count as a seller strike (FR-TNS-04).	M	T
FR-PAY-10	The system shall record every escrow state transition with time, triggering actor (buyer, seller, operator or system timer), reason and the amounts affected, in an append-only history that cannot be edited or deleted through the application.	M	T
FR-PAY-11	The system shall support full and partial refunds when a dispute is decided in the buyer's favour. In a partial refund, the refunded amount shall be taken from the item price first; platform commission shall be charged only on the part of the item price released to the seller; and the delivery fee shall be refunded only if the courier had not picked up the item.	M	T
FR-PAY-12	Refunds shall be paid to the original payment method through the provider's refund function. Each refund shall have its own ledger entry and provider reference, and a failed refund shall be retried (FR-PAY-16) and shown to an operator.	M	T

ID	Requirement (continued)	Pri	Ver
FR-PAY-13	When an order reaches a terminal escrow state, the system shall create one itemised settlement record showing: amount collected, item price, delivery fee, platform commission, courier payout, platform delivery margin, seller payout and any refund.	M	T
FR-PAY-14	All monetary amounts shall be integers in poisha. Percentages shall be applied with half-up rounding to the nearest poisha, and the seller's payout shall be calculated last as the remainder. In every settlement record, the parts shall add up exactly to the amount collected.	M	T
FR-PAY-15	A scheduled reconciliation job shall compare every non-terminal order's payment and refund status with the provider's records at least every CP-46. It shall correct missed confirmations through the normal idempotent path and report any discrepancy it cannot resolve to an operator.	M	T
FR-PAY-16	Failed calls to a payment provider shall be retried with exponential backoff and jitter up to a configured maximum, reusing the same idempotency key (SEC-PAY-07). After the maximum, the user shall see a clear failure message and no duplicate charge shall result.	M	T
FR-PAY-17	A seller shall register a payout account before their first payout. An MFS payout account shall be a wallet on the seller's own verified mobile number. A bank account shall be in a name matching the seller's KYC name and shall be checked by an operator.	M	T
FR-PAY-18	Adding or changing a payout account shall require step-up authentication (SEC-AUTH-08) and shall be notified to the seller's verified mobile number and e-mail. No payout shall be sent to a new or changed account until the cooling-off period CP-29 has passed.	M	T
FR-PAY-19	After release, the system shall create a payout of the seller's amount to the registered payout account and track it as `pending`, `sent` or `failed`. A failed payout shall be retried and the seller notified. In the academic deliverable, payouts are simulated with a recorded reference, and are labelled as simulated.	M	T
FR-PAY-20	If a card payment is charged back after release, the system should record it against the order, notify an operator, and recover the amount from the seller's next payouts.	C	T
FR-PAY-21	The system should give the buyer a receipt for every payment and refund, and give the seller a statement of every settlement and payout.	S	T

4.8 Delivery and Handover of Physical Items (DLV)

ID	Requirement	Pri	Ver
FR-DLV-01	At checkout, the system shall compute the straight-line distance between the buyer's and the seller's approximate locations.	M	T

ID	Requirement (continued)	Pri	Ver
FR-DLV-02	The seller shall choose, per listing, which fulfilment methods are allowed: self-pickup, courier, or both. Within the allowed methods, the system shall recommend self-pickup when the distance is at or below CP-14, and courier otherwise. The buyer may choose any allowed method; self-pickup shall add no delivery fee.	M	T
FR-DLV-03	For self-pickup, the system shall suggest at least one safe public meetup point near the midpoint of the two locations, drawn from a curated list (for example police stations, shopping-mall entrances or bank branches).	M	T
FR-DLV-04	For self-pickup, either party may propose a meetup point and time in the order view, and the other shall accept it before it is final. The agreed point and time shall be recorded on the order.	M	T
FR-DLV-05	Payment shall always be made through the platform before the meetup. The system shall not offer cash payment, and the order view shall show both parties that the item is already paid for.	M	T
FR-DLV-06	For self-pickup, the system shall show the buyer, and only the buyer, a one-time handover code, with an instruction to give it to the seller only after inspecting the item. The seller shall enter the code in the order view; a correct code records the handover as the delivery event. After CP-45 wrong entries, code entry shall be locked and both parties notified.	M	T
FR-DLV-07	Before the meetup, the system shall share only approximate locations between buyer and seller. For courier orders, exact pickup and drop-off addresses shall be sent only to the courier provider and shown to each party only for their own address.	M	T
FR-DLV-08	For courier fulfilment, the system shall calculate the delivery fare from the fare table CP-43, using the listing's weight and size classes, the delivery zone and the distance. The fare shall be fixed at checkout.	S	T
FR-DLV-09	The system shall show the buyer one total price (item plus delivery) without requiring the buyer to choose a courier.	S	T
FR-DLV-10	After payment is confirmed for a courier order, the system shall create a booking with the configured courier provider (or the mock) and track its status as `booked`, `picked_up`, `in_transit`, `delivered`, `delivery_failed` or `returned_to_seller`, shown to both parties. The provider's verified `delivered` status records the delivery event.	S	T
FR-DLV-11	If the courier has not picked up the item within CP-16 of payment, the order shall be cancelled and the buyer refunded in full (FR-PAY-08). If the item is not delivered within CP-17 of pickup, the buyer may open a non-delivery dispute.	S	T
FR-DLV-12	If the courier returns the item to the seller, the system shall cancel the order and refund the buyer in full, including the delivery fee. Any charge from the courier for the failed delivery shall be recorded as a platform cost in the revenue log.	S	T
FR-DLV-13	On the delivery event of a courier order, the system shall split the delivery fee between courier payout and platform delivery margin CP-26, and record both in the settlement record (FR-PAY-13).	S	T
FR-DLV-14	Whenever the mock courier is in use, the order view and the documentation shall state that courier bookings are simulated.	M	I

Table 4.8: Permitted escrow state transitions (FR-PAY-06). No other transition is allowed.

From	To	Actor	Condition
(none)	`held`	system	Payment confirmed and verified (FR-PAY-03–FR-PAY-05).
`held`	`released`	buyer	Buyer confirms receipt after the delivery event, or releases a game-account payment early (FR-GAM-17).
`held`	`released`	system	Auto-release timeout CP-19 after the delivery event, or end of the protection period CP-24 for a game account, with no dispute open.
`held`	`refunded`	system	Fulfilment deadline missed (FR-PAY-08), or a cancellation under FR-PAY-09.
`held`	`frozen_disputed`	buyer	Dispute opened within its window (FR-DSP-01, FR-GAM-14, FR-GAM-16).
`frozen_disputed`	`released`	operator	Dispute decided for the seller (FR-DSP-06).
`frozen_disputed`	`refunded`	operator	Dispute decided for the buyer, full refund.
`frozen_disputed`	`partially_refunded`	operator	Dispute decided with a partial refund (FR-PAY-11).
`frozen_disputed`	`held`	buyer	Buyer withdraws the dispute (FR-DSP-10).

4.9 Game-Account Escrow (GAM)

Game accounts use the order, payment, escrow and dispute requirements of Sections 4.7 and 4.12. The requirements below add what a game account needs in place of physical delivery: proof of ownership before listing, a sealed credential handover, a guided takeover and a protection hold (Supplementary Report, Section 5.2; Proposal, Section 1.7).

ID	Requirement	Pri	Ver
FR-GAM-01	The game-account feature shall be controlled by the feature switch CP-36. When it is off, new game-account listings and purchases shall be refused and active game-account listings hidden. Orders already paid shall continue to completion under these requirements.	M	T
FR-GAM-02	A verified seller shall be able to create a game-account listing recording: the game, the platform, the in-game player ID, and a description of the account's contents (for example level, items and linked purchases). The listing shall not contain or request any login detail.	M	T
FR-GAM-03	Before a game-account listing is published, the system shall issue the seller a one-time ownership code. The seller shall place the code in a visible field of the game profile (for example the bio or in-game name) and upload a screenshot showing the code and the player ID. An operator shall approve the listing only after checking both, and shall reject it with a reason otherwise.	M	T
FR-GAM-04	The system shall allow at most one active game-account listing per game and player ID. It shall refuse a new listing for a player ID whose earlier sale is still in its takeover window or protection period.	M	T

ID	Requirement (continued)	Pri	Ver
FR-GAM-05	Every game-account listing shall display a disclosure that the game's publisher may prohibit account transfers and may suspend or ban the account. The disclosure shall state that TrustBazaar's protection covers the handover, the takeover, and recovery by the seller during the protection period, but not action by the publisher. The system shall record the buyer's acknowledgement before accepting payment.	M	T
FR-GAM-06	A game account may be sold at a fixed price or by auction. No delivery fee applies, and the delivery requirements of Section 4.8 do not apply.	M	T
FR-GAM-07	At checkout, the buyer's browser shall generate an encryption key pair using the Web Cryptography API (SEC-DAT-10). The private key shall be non-extractable and shall remain only in that browser's storage. Only the public key shall be sent to the server, attached to the order. The buyer shall be told to complete the purchase and takeover in the same browser.	M	T
FR-GAM-08	The system should show the buyer and the seller a short fingerprint of the buyer's public key, so that they can compare it before the seller encrypts.	S	T
FR-GAM-09	The seller's browser shall encrypt the login details (login identifier, password and any recovery or backup codes) with the buyer's public key. Only the resulting ciphertext shall be sent to and stored by the server; the plaintext shall never leave the seller's browser.	M	T
FR-GAM-10	The system shall ask the seller for the credentials only after the payment is `held`. If the seller does not deliver them within CP-22, the order shall be cancelled and the buyer refunded in full (FR-PAY-08).	M	T
FR-GAM-11	The ciphertext shall be retrievable only by the buyer of that order, from an authenticated session. Every retrieval shall be recorded in the credential-access log with time, user and session (SEC-GAM-02).	M	T
FR-GAM-12	If the buyer loses access to the private key (for example by clearing browser data), the buyer may request one re-key during the takeover window. The buyer's browser shall generate a new key pair, and the seller shall be asked to encrypt again. The takeover window shall restart when the new ciphertext is delivered. The re-key shall be logged.	S	T
FR-GAM-13	The takeover window CP-23 shall start when the seller's ciphertext is delivered, whether or not the buyer has opened it. When the buyer retrieves the credentials, the system shall present a takeover checklist: change the password; change the recovery e-mail; change the recovery phone; remove linked social logins; and enable two-step verification. The buyer shall confirm each step, and the remaining takeover window shall be shown as a countdown.	M	T
FR-GAM-14	If, within the takeover window, the buyer reports that the credentials do not work, the system shall open a dispute of type `credentials_invalid` (FR-DSP-01). Once the buyer has confirmed changing the recovery e-mail, the system shall no longer accept a `credentials_invalid` report for that order.	M	T

ID	Requirement (continued)	Pri	Ver
FR-GAM-15	The takeover is complete when the buyer confirms every checklist step. If the takeover window ends without the buyer confirming every step or reporting a problem, the takeover shall be treated as complete at the end of the window. The moment of completion is the delivery event for the order.	M	T
FR-GAM-16	After the takeover is confirmed or treated as complete, the payment shall stay `held` for the protection period CP-24. During this period the buyer may open a dispute of type `seller_recovery` with evidence (for example the publisher's security e-mails or screenshots).	M	T
FR-GAM-17	The payment for a game-account order shall be released when the protection period ends, or earlier if the buyer chooses to release it. An open dispute shall prevent release until an operator decides it. The general auto-release timeout CP-19 shall not apply to game-account orders.	M	T
FR-GAM-18	When an operator confirms that a seller recovered a sold account, whether through a dispute during the protection period or a report after release, the system shall do three things. It shall suspend the seller. It shall add the seller's NID blind index to the blacklist, with four-eyes approval (FR-OPS-05). And it shall let the operator export the order's evidence (ownership proof, credential-access log, takeover confirmations and dispute history) for a complaint to law enforcement.	M	T
FR-GAM-19	The system shall delete the ciphertext once the order has reached a terminal escrow state and no dispute is open on it. The credential-access log shall be kept (Table 7.2).	M	T
FR-GAM-20	The system may warn a seller who appears to be sending a password or login details in chat, and direct them to the sealed handover instead.	C	T

4.10 Real-Time Chat (CHT)

ID	Requirement	Pri	Ver
FR-CHT-01	The system shall provide a chat thread for each pair of listing and prospective buyer, between that buyer and the seller. Only registered users may start a thread, and only from a listing.	M	T
FR-CHT-02	The system shall deliver a message to an online recipient in real time (NFR-PERF-04) and shall deliver queued messages when an offline recipient reconnects.	M	T
FR-CHT-03	The system shall allow images to be shared in a thread, subject to SEC-INP-04 and with metadata removed (SEC-DAT-08).	M	T
FR-CHT-04	The system shall keep the full history of a thread, retrievable by either participant, for the period in Table 7.2.	M	T
FR-CHT-05	The system should show a delivered and a read indicator for each message.	S	T
FR-CHT-06	The system shall allow a participant to report a thread or a message as abusive or fraudulent, adding it to the operator's report queue (FR-TNS-01).	M	T

ID	Requirement (continued)	Pri	Ver
FR-CHT-07	The system shall detect messages that appear to move payment or contact off the platform. These include mobile numbers, MFS wallet numbers, bank account numbers, links to external payment pages, and phrases asking for advance or direct payment (in Bangla and English). The system shall show both participants a warning that payments outside TrustBazaar are not protected. The message itself shall still be delivered.	M	T
FR-CHT-08	The system shall allow a user to block another user. A blocked user cannot send messages to, bid on the listings of, or buy from the user who blocked them. Orders already paid shall continue.	M	T
FR-CHT-09	Chat shall support plain text only. Web addresses should be shown as non-clickable text, with a warning.	S	T
FR-CHT-10	An operator may read a chat thread only as part of a dispute or a report that concerns it (FR-DSP-05), and every such access shall be logged (SEC-LOG-01).	M	T

4.11 Ratings, Reviews and Trust Signals (REV)

ID	Requirement	Pri	Ver
FR-REV-01	After an order reaches a terminal escrow state, the buyer and the seller may each rate the other (1–5 stars, with optional text) within CP-39.	S	T
FR-REV-02	The system shall not accept a rating for an order that was never paid, and shall allow at most one rating in each direction per order.	S	T
FR-REV-03	A rating may be edited within the edit period in CP-39 and is fixed afterwards.	S	T
FR-REV-04	The system shall show each user's average rating and number of completed transactions on their profile and listings.	S	T
FR-REV-05	The system shall show distinct badges for verified status and for an active Pro Seller subscription.	S	T
FR-REV-06	The rated user may post one public reply to a written review.	C	T
FR-REV-07	An operator may remove a review only when it breaks the content policy (for example abuse, or personal data), with a recorded reason. A removed review shall not count towards the average.	S	T

4.12 Dispute Resolution (DSP)

ID	Requirement	Pri	Ver
FR-DSP-01	The buyer may open a dispute, giving a type, a description and up to CP-33 evidence files. The types are: `not_as_described`, `damaged`, `not_received`, `credentials_invalid`, `seller_recovery` and `other`. A dispute may be opened only while the payment is `held` and within its window. For physical items the window is CP-18 after the delivery event; a `not_received` dispute may also be opened when the condition in FR-DLV-11 is met. For game accounts the windows are those in FR-GAM-14 and FR-GAM-16.	M	T

ID	Requirement (continued)	Pri	Ver
FR-DSP-02	Opening a dispute shall move the escrow to `frozen_disputed` at once, stopping every automatic release.	M	T
FR-DSP-03	The system shall notify the seller and add the dispute to the operator's dispute queue.	M	T
FR-DSP-04	The seller may respond with a statement and evidence within CP-20. If the seller does not respond, the operator shall decide on the evidence available.	M	T
FR-DSP-05	The system shall assemble a case file for the operator containing: the order and listing as they were at the time of sale; the escrow history; the settlement and ledger entries; the delivery or handover records; the chat thread for the listing; both parties' evidence; and, for game accounts, the ownership proof, takeover confirmations and credential-access log.	M	T
FR-DSP-06	The operator shall decide a dispute with one of the following outcomes, and shall record a reason in every case: (a) release to the seller; (b) full refund to the buyer; (c) partial refund (FR-PAY-11); or (d) refund after return of the item. Under (d), the return goes by courier at the system-quoted fare, the decision states which party pays that fare, and the refund is made when the seller's receipt of the item is recorded or the courier reports it delivered back.	M	T
FR-DSP-07	The system shall notify both parties of the outcome and its reason.	M	T
FR-DSP-08	Operators should decide disputes within CP-21. The system shall show each dispute's age in the queue.	S	A
FR-DSP-09	Each dispute shall have exactly one status out of `open`, `awaiting_seller`, `under_review`, `awaiting_return`, `decided` or `withdrawn`. Every change shall be logged with time, actor and reason.	M	T
FR-DSP-10	The buyer may withdraw a dispute before it is decided. The escrow then returns to `held`. Automatic release shall then take place at whichever is later: the original release time, or 24 hours after the withdrawal. A withdrawn dispute cannot be reopened with the same type.	M	T
FR-DSP-11	Only one dispute may be open on an order at a time. No dispute may be opened after the payment has been released or refunded; later complaints are handled as reports (FR-TNS-01), apart from the sanction in FR-GAM-18.	M	T
FR-DSP-12	Either party may request one review of a decision by a different operator within three days of the decision. A changed outcome shall require four-eyes approval.	C	T

4.13 Notifications (NTF)

ID	Requirement	Pri	Ver
FR-NTF-01	The system shall notify a bidder in real time when they are outbid.	M	T
FR-NTF-02	The system should notify users who are watching or bidding on an auction when it is within CP-38 of ending.	S	T

ID	Requirement (continued)	Pri	Ver
FR-NTF-03	The system shall notify the users concerned, in the app, of: payment confirmed; escrow released or refunded; every fulfilment status change; new chat messages; every dispute status change; KYC decisions; payout status; and listing approval, rejection or removal.	M	T
FR-NTF-04	The system shall show each user a history of their notifications.	S	T
FR-NTF-05	In-app notifications shall always be sent. The notices in FR-NTF-03 should also be sent by e-mail. SMS shall be used only for OTPs and the security notices in FR-NTF-06.	S	T
FR-NTF-06	The system shall always notify a user, by SMS and e-mail, of: a sign-in from a new device; a change of password, mobile number or e-mail; enabling or disabling MFA; and adding or changing a payout account. Users shall not be able to switch these notices off.	M	T
FR-NTF-07	The system should remind users of each deadline that applies to them (payment window, meetup handover, courier dispatch, credential delivery, takeover window, dispute window and protection period) at the times in CP-38.	S	T
FR-NTF-08	No notification shall contain a password, an OTP other than in its own OTP message, game-account credentials, a full NID number, or another user's contact details.	M	T

4.14 Monetization (MON)

ID	Requirement	Pri	Ver
FR-MON-01	The system shall deduct a platform commission CP-25, a percentage of the item price, from the seller's payout on every sale. It shall be charged only on the part of the item price actually released to the seller (FR-PAY-11).	M	T
FR-MON-02	The system shall apply the lower Pro Seller commission rate in CP-25 to orders of a seller with an active Pro Seller subscription when the order is created.	C	T
FR-MON-03	The system shall retain the delivery margin CP-26 from each courier delivery fee (FR-DLV-13).	S	T
FR-MON-04	The system shall not charge any fee for publishing a standard listing and shall not charge sellers per view or per click.	M	T
FR-MON-05	A seller may pay a flat fee CP-37 to feature a listing at the top of search results or on the home page for a fixed period. Featured listings shall be labelled "Featured" wherever they appear.	C	T
FR-MON-06	The system shall offer a recurring Pro Seller subscription granting the lower commission, the higher listing limit CP-28 and a sales analytics view.	C	T
FR-MON-07	Subscription billing and renewal shall use the same payment providers as purchases, confirmed by webhook under FR-PAY-02 to FR-PAY-04.	C	T
FR-MON-08	On cancellation, or after repeated failure of renewal payment, the account shall revert to standard status. Listings above the standard limit shall stay active until they end, but no new listing shall be accepted while the limit is exceeded.	C	T

ID	Requirement (continued)	Pri	Ver
FR-MON-09	The system shall record every commission, delivery margin, featured-listing fee, subscription charge and fee refund in a revenue log kept separate from the buyer and seller settlement records.	M	T
FR-MON-10	The system shall show sellers the commission and delivery-margin rates before they create a listing, and shall show the buyer the full price breakdown at checkout. The rates that apply to an order are those in force when the order is created.	M	T

4.15 Trust and Safety (TNS)

ID	Requirement	Pri	Ver
FR-TNS-01	Any registered user may report a listing, a user or a chat message as fraudulent, counterfeit, prohibited, misrepresented or abusive. The report shall be added to the operator's report queue.	M	T
FR-TNS-02	The system should flag for review a seller who relists a similar item shortly after a cancelled or disputed sale.	S	T
FR-TNS-03	An operator may apply the following sanctions: a warning; removal of a listing; suspension of selling; suspension of bidding and buying; or suspension of the account. Each sanction shall have a recorded reason and an end date or "until review", and the user shall be notified of the reason.	M	T
FR-TNS-04	The system should give a seller a strike for: cancelling unilaterally after payment; missing a fulfilment deadline; or losing a dispute. On reaching CP-47 strikes, the seller's selling rights should be suspended automatically, pending operator review.	S	T
FR-TNS-05	While an account is suspended, the user's listings shall be hidden, and new bids, purchases and listings refused. Paid orders shall continue to completion under the normal escrow rules. If the suspension is for suspected fraud, payouts to the user shall be held until an operator reviews them.	M	T
FR-TNS-06	The system shall keep an NID blacklist of identities banned for fraud (FR-GAM-18, or an operator decision under FR-TNS-03). A blacklisted identity cannot be verified on any account. Each entry shall record its reason and the related order. Removing an entry shall require four-eyes approval.	M	T
FR-TNS-07	The system should limit the value of a single order and the total value of open orders for users verified fewer than 30 days ago, as set in CP-27.	S	T
FR-TNS-08	The system should flag for review accounts that share a device, a payout account or a payment instrument with another account, especially where one account bids on the other's auctions.	S	T
FR-TNS-09	The person who made a report should be told when it has been reviewed and whether action was taken, without being given details of any sanction.	S	T

4.16 Operator and Administrator Functions (OPS)

ID	Requirement	Pri	Ver
FR-OPS-01	The system shall provide operators with these queues and no others: KYC submissions; game-account ownership proofs; listings in `pending_review`; reports; flagged activity; disputes; bank payout-account checks; and payment discrepancies.	M	T
FR-OPS-02	An operator shall be able to perform only the following actions: approve, reject or revoke KYC; approve or reject a listing under review, or remove a listing for a policy breach; approve or reject an ownership proof; decide a dispute; void a bid (FR-AUC-10); cancel an auction that has bids (FR-LST-08); apply or lift a sanction; add an identity to the NID blacklist; approve or reject a bank payout account; resolve a payment discrepancy; remove a review (FR-REV-07); and export an evidence pack (FR-GAM-18). Every action shall require a reason. No generic create, edit or delete of listings, users, orders or payments shall exist.	M	T
FR-OPS-03	An administrator shall be able to perform only the following actions: create, disable and assign roles to staff accounts; reset a staff member's MFA, with approval from a second administrator; change configurable parameters within their allowed ranges; turn feature switches on or off; and read the audit log. An administrator shall not be able to view KYC documents, chats, dispute evidence or case files, or decide any case.	M	T
FR-OPS-04	Staff accounts shall be created only by an administrator; the first administrator shall be created by a deployment-time command and not through the web interface. Staff accounts shall have no self-registration and shall not be usable to buy, sell or bid.	M	T
FR-OPS-05	The actions listed in CP-30 shall take effect only after approval by a second staff member with the required role, who is not the one who proposed the action.	M	T
FR-OPS-06	A staff member shall not be able to act on a case involving a user account registered with the same mobile number, e-mail or NID as their own, or a user with whom they have declared a conflict of interest.	M	T
FR-OPS-07	Every staff action shall be logged with: staff identity; time; the object affected; the values before and after; the reason; and, where applicable, the approver (SEC-LOG-01).	M	T
FR-OPS-08	Changes to parameters shall be versioned. A change shall apply only to listings, auctions and orders created after it, which keep the values in force at their creation.	M	T
FR-OPS-09	The system shall reject a parameter change that breaks a rule in Table 8.1, for example an auto-release timeout CP-19 not longer than the dispute window CP-18.	M	T

4.17 Privacy and Data-Subject Rights (PRV)

ID	Requirement	Pri	Ver
FR-PRV-01	Before collecting personal data, the system shall show a privacy notice stating: the purposes; the categories of data collected; how long each is kept (Table 7.2); who receives it (payment, courier and messaging providers); any transfer outside Bangladesh; and how to withdraw consent. This is as required by the PDPO [R10].	M	I

ID	Requirement (continued)	Pri	Ver
FR-PRV-02	Processing that is not needed for a transaction, such as marketing messages and personalised recommendations, should require separate opt-in consent that the user can withdraw at any time.	S	T
FR-PRV-03	A user should be able to download a copy of their personal data and transaction history in a machine-readable format.	S	T
FR-PRV-04	On account closure, the system shall delete or anonymise personal data within CP-41, except data that must be kept under Table 7.2 (for example settlement records, audit logs and blacklist entries).	M	T
FR-PRV-05	KYC data shall be used only to verify identity, to prevent fraud and to meet legal obligations, and never for marketing, recommendations or profiling.	M	I
FR-PRV-06	Personal data shall be disclosed to an authority only on a documented lawful request. The disclosure shall be approved under four-eyes control and logged, and the user shall be told unless the law forbids it.	S	I

5 Security Requirements

TrustBazaar holds identity documents, moves money and holds game-account credentials, so security is part of the product's central claim. This chapter states the security objectives, the threats the system must withstand, and the requirements that follow from them. The baseline is OWASP ASVS 5.0 Level 2 [R3], with NIST SP 800-63B-4 [R5] for authentication and PCI DSS v4.0.1 [R6] for card data. How each control is implemented is a design matter for the SDD.

5.1 Security Objectives

SO-1 **Money moves only by the rules**: no actor, including an operator, can release or redirect escrowed funds except by a transition in Table 4.8.

SO-2 **Identity data stays confidential**: KYC images, NID numbers and selfies are readable only by the owning user and by the operator reviewing them, and only while doing so.

SO-3 **Game-account credentials are unreadable to the platform**: the server and its staff never hold them in readable form.

SO-4 **Auctions cannot be manipulated**: bid order, end time and the winner are decided by the server and cannot be altered by any client.

SO-5 **Accounts cannot be taken over cheaply**: credential stuffing, OTP abuse and session theft are resisted.

SO-6 **Every consequential action is attributable**: actions on money, identity, credentials and cases leave a tamper-evident record.

5.2 Threats Considered

Threat actor	Examples of what they attempt	Main requirements
External attacker	Credential stuffing, OTP flooding (SMS pumping), injection, XSS, CSRF, enumeration of other users' orders or documents (IDOR), forged webhooks	SEC-AUTH, SEC-SES, SEC-ACC, SEC-INP, SEC-WEB, SEC-PAY
Fraudulent seller	Fake listings, advance-payment requests in chat, shill bidding, recovering a sold game account, payout to a stolen account	FR-CHT-07, FR-AUC-18, FR-GAM, FR-PAY-17, FR-PAY-18
Fraudulent buyer	False "not received" or "credentials invalid" claims, keeping an account and claiming a refund, chargebacks after release	FR-DLV-06, FR-GAM-14, FR-PAY-20
Multi-account or identity fraud	Several accounts for one person, fake or borrowed NIDs, returning after a ban	FR-KYC-04, FR-TNS-06, FR-TNS-08
Malicious or compromised staff	Reading KYC documents without cause, releasing escrow to an accomplice, deciding own cases, changing parameters to favour an order	FR-OPS-02 to FR-OPS-08, SEC-ACC-06, SEC-LOG
Data or backup theft	Copy of the database or a backup leaked	SEC-DAT-02, SEC-DAT-03, SEC-DAT-06, FR-GAM-09
Supply-chain compromise	Malicious dependency or container image, leaked CI secret	SEC-SDL

Out of scope: attacks on the payment providers' own systems, compromise of a user's own device, and national-level adversaries. Assumption AS-6 states the limit of the game-credential protection.

5.3 General

ID	Requirement	Pri	Ver
SEC-GEN-01	The system shall meet the Level 2 requirements of OWASP ASVS 5.0 [R3]. Before each release, an ASVS checklist shall record, for each requirement, whether it is met, not applicable, or deliberately deviated from, with the reason.	M	A
SEC-GEN-02	A threat model of each feature area shall be recorded in the SDD before that area is implemented, and reviewed when the area changes.	M	A
SEC-GEN-03	Every security requirement marked T shall have at least one automated test in the CI pipeline.	M	T

5.4 Authentication (SEC-AUTH)

ID	Requirement	Pri	Ver
SEC-AUTH-01	Passwords shall be at least 15 characters long, or at least 8 characters for an account with MFA enabled; when a user turns MFA off, a password shorter than 15 characters must be changed. At least 64 characters and all printable Unicode characters, including spaces, shall be accepted. No composition rules, periodic expiry, hints or security questions shall be used [R5].	M	T
SEC-AUTH-02	New and changed passwords shall be checked against a list of breached and commonly used passwords and against context-specific words (for example “trustbazaar” or the user’s own name or number), and rejected if found.	M	T
SEC-AUTH-03	Passwords shall be stored only as salted Argon2id hashes, with at least the parameters OWASP recommends (19 MiB memory, 2 iterations, parallelism 1). bcrypt shall not be used: it ignores input beyond 72 bytes, and a Bangla passphrase of 25 characters can already exceed that. Passwords shall never be logged or stored in plaintext.	M	T
SEC-AUTH-04	After CP-04 failed sign-ins for one account, the system shall delay further attempts progressively, and shall also limit attempts per source address. The account owner shall be notified, and the throttling shall not lock out the legitimate owner permanently.	M	T
SEC-AUTH-05	Sign-in, registration and password-reset responses shall not reveal whether a mobile number or e-mail is registered. Their response times shall not differ measurably either.	M	T
SEC-AUTH-06	Registration shall resist enumeration as in SEC-AUTH-05: a duplicate number or e-mail shall get the same response as a new one, and the owner of the existing account shall be notified instead.	M	T
SEC-AUTH-07	MFA shall be mandatory for operator and administrator accounts, using TOTP or a phishing-resistant authenticator (WebAuthn/passkey). SMS shall not be accepted as a staff second factor.	M	T
SEC-AUTH-08	Step-up authentication (TOTP if enabled, otherwise an OTP to the verified mobile number) shall be required, even in a valid session, for: changing password, mobile number or e-mail; turning MFA off; adding or changing a payout account; releasing a game-account payment early; and closing the account.	M	T
SEC-AUTH-09	OTPs shall be 6 random digits from a cryptographically secure generator, single-use, valid for CP-05, and stored only as hashes. Entry attempts shall be limited per OTP, and sends shall be limited per number and per source address (CP-05) to prevent SMS pumping.	M	T
SEC-AUTH-10	Password-reset tokens shall carry at least 128 bits of randomness, be single-use, expire after CP-06, and be stored only as hashes. A successful reset shall end all of the user’s sessions and notify the user (FR-NTF-06).	M	T
SEC-AUTH-11	Changing a password shall end every other session of that user.	M	T
SEC-AUTH-12	The system should recognise devices previously used by an account, and should treat a sign-in from an unrecognised device as new for FR-NTF-06.	S	T

5.5 Session Management (SEC-SES)

ID	Requirement	Pri	Ver
SEC-SES-01	Access tokens shall be short-lived (CP-01) and signed with an algorithm fixed on the server; tokens with `alg=none` or an unexpected algorithm shall be rejected.	M	T
SEC-SES-02	Refresh tokens shall be rotated on every use, subject to an idle limit and an absolute limit (CP-02), and stored only as hashes on the server. Reuse of an already rotated refresh token shall revoke the whole session family and notify the user.	M	T
SEC-SES-03	Session tokens shall be kept in cookies marked `HttpOnly`, `Secure` and `SameSite`, and shall never be placed in browser local storage, in URLs or in logs.	M	T
SEC-SES-04	Every state-changing request authenticated by cookie shall be protected against cross-site request forgery by an anti-CSRF token or an equivalent origin check, in addition to the `SameSite` attribute.	M	T
SEC-SES-05	Sign-out, "end session", password change and account suspension shall invalidate the affected sessions on the server immediately; an access token still within its lifetime shall then be refused.	M	T
SEC-SES-06	Staff sessions shall be subject to the shorter idle and absolute limits in CP-03.	M	T
SEC-SES-07	A WebSocket connection shall be authenticated when it is opened and closed when its session ends or is revoked. Joining an auction room or a chat room shall be authorised on the server: a user may join only chats they participate in, and the order rooms of their own orders.	M	T

5.6 Access Control (SEC-ACC)

ID	Requirement	Pri	Ver
SEC-ACC-01	Every request shall be authorised on the server, with access denied by default. Hiding a control in the user interface shall never count as access control.	M	T
SEC-ACC-02	Every request that names an object (order, listing, chat, KYC document, dispute, payout account, ciphertext) shall be checked to confirm that the requester is allowed to access that particular object. A user shall not be able to read or change another user's data by altering an identifier.	M	T
SEC-ACC-03	The roles Guest, Registered user, Verified user, Pro Seller, Operator and Administrator shall have the permissions in Section 2.3 and Section 4.16, and no others. Role checks shall be made on the server for every protected function.	M	T
SEC-ACC-04	Request bodies shall be accepted only for fields the endpoint explicitly allows. Fields such as role, KYC status, price after bidding, escrow state or seller payout shall never be settable from client input.	M	T
SEC-ACC-05	Staff views shall mask personal data by default (for example, phone and NID showing only their last digits), and show the full value only where the task requires it, logging each such display.	M	T
SEC-ACC-06	KYC images shall be viewable only by the owning user and by an operator assigned to review that submission or a case involving that user. Every view shall be logged with the reason.	M	T

5.7 Data Protection and Cryptography (SEC-DAT)

ID	Requirement	Pri	Ver
SEC-DAT-01	All external connections shall use TLS 1.2 or later (TLS 1.3 preferred), with HTTP Strict Transport Security on every response [R9]. Plain HTTP shall only redirect to HTTPS. Connections to providers shall verify certificates.	M	T
SEC-DAT-02	KYC images and dispute evidence shall be encrypted at rest with AES-256-GCM, or an equivalent authenticated cipher, under keys held outside the database. They shall never be reachable through a public or guessable URL.	M	T
SEC-DAT-03	NID and passport numbers shall be stored encrypted. For the uniqueness check (FR-KYC-04) and the blacklist (FR-TNS-06), a blind index (HMAC-SHA-256 under a separate secret key) shall be used, so that a copy of the database does not reveal the numbers.	M	T
SEC-DAT-04	Protected files shall be served only through short-lived signed URLs (CP-31) issued to an authorised viewer after the check in SEC-ACC-06.	M	T
SEC-DAT-05	Encryption keys, signing secrets and provider credentials shall be kept in environment configuration or a secrets manager, never in source control, container images or logs. Every key shall carry a version so that it can be rotated without losing access to older data.	M	I
SEC-DAT-06	Backups shall be encrypted, and access to them shall be restricted and logged.	S	T
SEC-DAT-07	Passwords, OTPs, tokens, NID numbers, payout account numbers and game-account ciphertext shall never be written to application logs, error messages, analytics or URLs. Mobile numbers and e-mail addresses in logs shall be masked.	M	T
SEC-DAT-08	Metadata (including EXIF location data) shall be removed from every uploaded image before it is stored or shown.	M	T
SEC-DAT-09	Random values used for security (tokens, codes, keys, identifiers that grant access) shall come from a cryptographically secure generator.	M	T
SEC-DAT-10	Game-account credential encryption shall use standard Web Cryptography API algorithms, either RSA-OAEP with SHA-256 and a key of at least 3072 bits, or ECDH on P-256 with AES-256-GCM. No other algorithm shall be used and no custom construction written (C-4).	M	I
SEC-DAT-11	Public identifiers of orders, listings, files and users shall not be sequential or predictable.	M	T

5.8 Game-Account Credential Security (SEC-GAM)

ID	Requirement	Pri	Ver
SEC-GAM-01	Game-account login details shall never be transmitted to or stored on the server in plaintext, or in any form that the server or a staff member can decrypt.	M	T

ID	Requirement (continued)	Pri	Ver
SEC-GAM-02	The credential-access log (FR-GAM-11) shall be append-only and shall be kept for the lifetime of the order and of any dispute on it, and then for the period in Table 7.2.	M	T
SEC-GAM-03	Credential-entry and credential-view pages shall load no third-party scripts, and shall be protected by the strict content security policy in SEC-WEB-01.	M	T

5.9 Input, Output and File Handling (SEC-INP)

ID	Requirement	Pri	Ver
SEC-INP-01	Every input shall be validated on the server against an explicit schema (type, length, range, format). Requests with unknown or invalid fields shall be rejected.	M	T
SEC-INP-02	Database access shall use parameterised queries or the ORM's parameter binding only. Building a query by concatenating user input shall not be allowed, and this shall be checked by static analysis (SEC-SDL-03).	M	I
SEC-INP-03	User-supplied text (listing text, chat, reviews, display names) shall be treated as plain text and encoded for its output context. User-supplied HTML shall never be rendered.	M	T
SEC-INP-04	Uploads shall be accepted only as JPEG, PNG or WebP, identified by file content and not by name or declared type, within the limits in CP-33. Each upload shall be re-encoded, stored under a random name outside any executable path, and served with a fixed content type and `X-Content-Type-Options: nosniff`. They should also be scanned for malware.	M	T
SEC-INP-05	The server shall not fetch any web address supplied by a user.	M	T
SEC-INP-06	Error responses shown to users shall be generic and shall carry a correlation identifier. Stack traces, queries and internal paths shall appear only in protected logs.	M	T

5.10 Browser and API Hardening (SEC-WEB)

ID	Requirement	Pri	Ver
SEC-WEB-01	Every page shall be served with a content security policy that forbids inline scripts (nonces or hashes only), restricts script sources to the site and the named payment provider, and sets `frame-ancestors 'none'`, except on any page a payment provider must frame.	M	T
SEC-WEB-02	Responses shall set `X-Content-Type-Options`, a strict `Referrer-Policy` and a restrictive `Permissions-Policy`. Camera and geolocation shall be allowed only on the pages that need them.	M	T
SEC-WEB-03	Cross-origin requests to the API shall be allowed only from the configured web-client origins.	M	T
SEC-WEB-04	Any third-party script or stylesheet loaded from another origin should carry a Subresource Integrity hash.	S	I

ID	Requirement (continued)	Pri	Ver
SEC-WEB-05	The API shall return only the fields each view needs. Internal fields (hashes, blind indexes, other users' contact details, proxy maximums) shall never appear in responses.	M	T

5.11 Payment Security (SEC-PAY)

ID	Requirement	Pri	Ver
SEC-PAY-01	Card data shall be entered only on Stripe-hosted pages or Stripe-hosted fields, so that card numbers never reach TrustBazaar's servers. The payment pages shall meet the SAQ A conditions of PCI DSS v4.0.1 [R6], including protection of the page against malicious scripts.	M	I
SEC-PAY-02	MFS wallet PINs and OTPs shall be entered only on the provider's own pages. TrustBazaar shall never request, receive or store them, or store raw card or wallet credentials; only provider tokens and references shall be stored.	M	I
SEC-PAY-03	Every provider webhook or callback shall be accepted only after its signature (or the provider's equivalent verification query) has been checked with the secret for the current environment.	M	T
SEC-PAY-04	Webhooks shall be rejected if their timestamp is outside CP-32, and every event identifier shall be stored, so that a replayed event has no effect (FR-PAY-04).	M	T
SEC-PAY-05	Sandbox and production provider credentials shall be separate. A build configured for sandbox shall refuse production credentials, and the reverse.	M	T
SEC-PAY-06	Amounts, currency and order references shall be computed on the server; any amount sent by the client shall be ignored.	M	T
SEC-PAY-07	Every payment, refund and payout request to a provider shall carry an idempotency key unique to that operation, so that a retry can never charge, refund or pay twice.	M	T

5.12 Abuse Prevention (SEC-ABU)

ID	Requirement	Pri	Ver
SEC-ABU-01	The system shall rate-limit sign-in, registration, OTP requests, password reset, bidding, chat, listing creation, reporting, search and checkout, per account and per source address, using the limits in CP-04, CP-05 and CP-35. A limited request shall receive a clear retry-after response.	M	T
SEC-ABU-02	The system should present a human-verification challenge after repeated failures or unusual request rates on registration, sign-in and OTP requests.	S	T
SEC-ABU-03	Rate-limit state shall be shared across backend instances, so that adding instances does not multiply the allowance.	M	T

5.13 Logging, Audit and Monitoring (SEC-LOG)

ID	Requirement	Pri	Ver
SEC-LOG-01	The system shall log these security events: sign-in success and failure; MFA changes; password, mobile and e-mail changes; session revocation; OTP failures; every staff action (FR-OPS-07); every view of KYC data or case files; every credential retrieval; every bid; every payment, escrow, refund and payout state change; every parameter or feature-switch change; and every rejected escrow transition (FR-PAY-06).	M	T
SEC-LOG-02	The audit log shall be append-only through the application and tamper-evident: each entry shall include a hash of the previous entry, and a verification job shall report any break in the chain.	M	T
SEC-LOG-03	Log entries shall record UTC time from an NTP-synchronised clock, the actor, the source address and a correlation identifier.	M	T
SEC-LOG-04	The audit log shall be readable only by administrators (read-only) and by operators for the cases they handle. It shall not be changeable or deletable by any application role.	M	T
SEC-LOG-05	The system should alert the team on at least these events: a spike in failed sign-ins; OTP send volume above normal; one staff member viewing many KYC records in a short time; a break in the audit-log hash chain; repeated webhook signature failures; and any rejected escrow transition.	S	T

5.14 Secure Development and Supply Chain (SEC-SDL)

ID	Requirement	Pri	Ver
SEC-SDL-01	The main branch shall be protected. Every change shall be merged by pull request after passing CI and after review by a team member other than the author. Changes to authentication, payment, escrow, credential handling or authorisation shall be reviewed specifically for security.	M	I
SEC-SDL-02	The CI pipeline shall run linting, unit tests, the concurrency suite and the security tests on every push and pull request to the main branch.	M	T
SEC-SDL-03	Static analysis (CodeQL) shall run on every pull request and weekly. A new high-severity finding shall block the merge until it is fixed or documented as a false positive.	M	I
SEC-SDL-04	Dependencies shall be pinned by lock file and scanned for known vulnerabilities on every pull request (`npm audit` and Dependabot). The build shall fail on a known critical or high vulnerability with an available fix, unless a documented exception exists.	M	T
SEC-SDL-05	Secret scanning with push protection shall be enabled for the repository. Any secret found in history shall be treated as compromised and rotated.	M	I
SEC-SDL-06	Container images should be scanned for known vulnerabilities before release.	S	T
SEC-SDL-07	A software bill of materials (SBOM) in a standard format may be produced for each release.	C	I

ID	Requirement (continued)	Pri	Ver
SEC-SDL-08	A dynamic scan (OWASP ZAP baseline) should be run against the release candidate, and its findings triaged before the demonstration.	S	T
SEC-SDL-09	The automated tests shall include negative authorisation tests for each protected endpoint: another user's object; a lower role; no session; and an expired session.	M	T

5.15 Deployment and Infrastructure (SEC-INF)

ID	Requirement	Pri	Ver
SEC-INF-01	Containers shall run as non-root users from minimal base images, with only the ports they need exposed.	M	I
SEC-INF-02	PostgreSQL and Redis shall not be reachable from outside the internal container network, and both shall require authentication.	M	T
SEC-INF-03	The application shall connect to the database with an account that cannot change the schema. Migrations shall run under a separate account.	M	I
SEC-INF-04	Development, test and production environments shall be separate, with separate credentials. Production personal data shall never be copied into development or test.	M	I
SEC-INF-05	Production configuration shall disable debug output and automatic schema synchronisation.	M	T

5.16 Vulnerability and Incident Management (SEC-IRM)

ID	Requirement	Pri	Ver
SEC-IRM-01	Known vulnerabilities in the deployed system should be fixed within CP-42 according to severity.	S	I
SEC-IRM-02	The site may publish a security contact in `/.well-known/security.txt` [R9].	C	I
SEC-IRM-03	An incident-response procedure should define roles, how incidents are contained and evidence preserved, and how affected users and the authority are notified of a personal-data breach as required by the PDPO [R10].	S	I
SEC-IRM-04	Administrators should be able, with four-eyes approval, to: suspend new orders and payouts; turn off the game-account feature (CP-36); end all user sessions; and rotate signing keys, each without redeploying the application.	S	T

6 Other Non-Functional Requirements

6.1 Performance (PERF)

Performance targets are measured under the reference load in NFR-PERF-01, on the Docker Compose deployment, using a load-testing tool, and reported as the 95th percentile (p95) of server-side response time unless stated otherwise.

ID	Requirement	Pri	Ver
NFR-PERF-01	Reference load: 500 concurrent signed-in users; 200 clients viewing one auction; 20 bids per second on that auction for 60 seconds; 50 simultaneous purchase attempts on the last unit of one fixed-price listing; and a catalogue of 100,000 listings.	M	A
NFR-PERF-02	A bid shall be accepted or rejected within 500 ms (p95).	M	T
NFR-PERF-03	A change in auction state shall reach every connected viewer of that auction within 1 second (p95), measured from acceptance of the bid to receipt by the client.	M	T
NFR-PERF-04	A chat message shall reach an online recipient within 1 second (p95).	M	T
NFR-PERF-05	A filtered search shall return within 2 seconds (p95).	M	T
NFR-PERF-06	A verified provider confirmation shall move the order to `held` within 5 seconds of receipt (p95).	M	T
NFR-PERF-07	On a simulated 4G connection and a mid-range phone profile, the home, listing and checkout pages should reach Largest Contentful Paint within 2.5 seconds.	S	T
NFR-PERF-08	Under the reference load, the correctness guarantees in Appendix A shall hold without exception: no duplicate highest bid, no over-sale, no duplicate settlement.	M	T

6.2 Reliability and Availability (REL)

ID	Requirement	Pri	Ver
NFR-REL-01	Restarting any single container, including Redis, shall not change any auction's authoritative end time and shall not lose an accepted bid, a confirmed payment or an escrow transition. Authoritative state shall be held durably in PostgreSQL.	M	T
NFR-REL-02	A bid, purchase reservation, payment confirmation or escrow transition shall be acknowledged only after it has been durably committed.	M	T

ID	Requirement (continued)	Pri	Ver
NFR-REL-03	Scheduled actions (auction close, payment-window expiry, checkout-hold expiry, fulfilment deadlines, auto-release, end of protection period, reconciliation) shall be idempotent and shall catch up after downtime. An action that fell due during an outage shall run once on recovery, based on the recorded times, and never twice.	M	T
NFR-REL-04	When a payment or courier provider is unavailable, the system should refuse new checkouts that depend on it, with a clear message, and leave existing orders unaffected. The payment window of an auction that ends during a provider outage should be extended by the length of the outage.	S	T
NFR-REL-05	**(prod)** The database should be backed up daily, with continuous write-ahead-log archiving, for a recovery point objective of 15 minutes and a recovery time objective of 4 hours. A restore should be tested before each release.	S	T
NFR-REL-06	**(prod)** Target availability is 99.5% per calendar month, excluding announced maintenance.	C	A

6.3 Usability and Accessibility (USE)

ID	Requirement	Pri	Ver
NFR-USE-01	A first-time bidder shall be able to read the auction rules (increment, proxy bidding, reserve, anti-sniping) from the auction page without leaving it.	M	D
NFR-USE-02	The KYC wizard shall state the document requirements before capture and show the current review status at every step.	M	D
NFR-USE-03	The takeover checklist shall show the time remaining in the takeover window and the date on which the protection period ends.	M	D
NFR-USE-04	The interface should be available in Bangla and English, switchable at any time, with all money-related and deadline text available in both languages.	S	D
NFR-USE-05	Every view shall be usable at a viewport width of 360 CSS pixels without horizontal scrolling.	M	T
NFR-USE-06	The interface should conform to WCAG 2.2 Level AA [R7].	S	A
NFR-USE-07	The order view shall describe the money's state in plain language (for example "Your payment is held by TrustBazaar. The seller is paid when you confirm receipt, or automatically on 20 Oct at 18:00 unless you open a dispute").	M	D
NFR-USE-08	All dates and times shall be shown in Asia/Dhaka time with the date, and deadlines shall be shown as both a time and a countdown.	M	T

6.4 Maintainability and Portability (MNT)

ID	Requirement	Pri	Ver
NFR-MNT-01	The system shall run as four containers orchestrated by Docker Compose: PostgreSQL, Redis, the backend (including its real-time gateway) and the web client. Health checks shall make the backend wait for the database and cache.	M	I
NFR-MNT-02	Automated tests shall cover at least: concurrent bidding; anti-sniping; proxy bidding; the last-unit purchase race; webhook idempotency and replay; escrow transitions (permitted and forbidden); fee-split arithmetic; the game-account release rules; and the authorisation tests in SEC-SDL-09.	M	T
NFR-MNT-03	Line coverage of the auction, order, payment, escrow, delivery and game-account modules should be at least 70%.	S	A
NFR-MNT-04	Database schema changes shall be made only by versioned migrations kept in the repository. Automatic schema synchronisation shall be used only in local development.	M	I
NFR-MNT-05	The HTTP API should be documented in OpenAPI format generated from the code.	S	I
NFR-MNT-06	Every value in Table 8.1 shall be read from configuration, not hard-coded.	M	I
NFR-MNT-07	The code shall pass the repository's ESLint rules with no errors in CI.	M	I
NFR-MNT-08	The whole system shall start from a clean checkout with one documented command on any Linux, macOS or Windows host with Docker installed.	M	T

6.5 Scalability (SCL)

ID	Requirement	Pri	Ver
NFR-SCL-01	Real-time messages shall be distributed through a publish/subscribe channel, so that further backend instances can be added without any instance needing every client connection.	M	T
NFR-SCL-02	No backend instance shall hold state that another instance needs in order to serve a request correctly; a request shall be servable by any instance.	S	T
NFR-SCL-03	Performance targets NFR-PERF-02 to NFR-PERF-05 shall hold with the catalogue at 100,000 listings and with 1,000,000 bids stored.	S	A

6.6 Observability (OBS)

ID	Requirement	Pri	Ver
NFR-OBS-01	The backend shall expose a liveness check and a readiness check that reports database and cache connectivity.	M	T
NFR-OBS-02	Application logs shall be structured (JSON), with level, time, correlation identifier and module, subject to SEC-DAT-07.	M	I

ID	Requirement (continued)	Pri	Ver
NFR-OBS-03	The backend should expose metrics for request rates, error rates, response times, active WebSocket connections, queue depths and job outcomes.	S	T

6.7 Legal and Regulatory Compliance (CMP)

ID	Requirement	Pri	Ver
NFR-CMP-01	Collection, storage, retention and deletion of personal data shall follow the PDPO [R10], including consent and notice at collection (FR-PRV-01), the retention schedule in Table 7.2, and constraint C-8 in production.	M	I
NFR-CMP-02	**(prod)** Escrow shall be operated through a Bangladesh Bank-licensed provider (C-7), in line with the escrow instructions for digital commerce [R12].	M	I
NFR-CMP-03	Card handling shall stay within PCI DSS SAQ A scope (SEC-PAY-01).	M	I
NFR-CMP-04	The terms of use shall state at least: the age requirement; prohibited items; the fees; the escrow, release and dispute rules; the game-account risk disclosure; the sanctions; and the platform's role and limits of liability.	M	I
NFR-CMP-05	The academic deliverable shall make clear, on every payment and courier screen and in the documentation, that payments and courier bookings are simulated (C-2, C-3).	M	I

7 Data Requirements

This chapter states what information the system must keep, how sensitive it is and how long it is kept. The entities, fields and relationships that implement it are specified in the SDD.

7.1 Information the System Shall Keep

ID	Requirement	Pri	Ver
DR-01	Accounts and authentication: identity of the account; verified contact details; password hash; MFA settings; sessions; consent records (FR-ACC-04).	M	I
DR-02	KYC: submissions, their images, the document details as printed, the blind index, status history and operator decisions.	M	I
DR-03	Listings, including their status history and any clarifications, and a copy of the listing as it was when each order was created.	M	I
DR-04	Bids, including proxy maximums and the server receipt time of each.	M	I
DR-05	Orders, escrow state history, settlement records, refunds, payouts, provider references and webhook event identifiers.	M	I
DR-06	Fulfilment: meetup proposals and agreements, handover-code events, courier bookings and status history.	M	I
DR-07	Game accounts: listing details, ownership proofs, public keys, ciphertext until deletion, takeover confirmations, credential-access log.	M	I
DR-08	Chat threads and messages, reviews, disputes with evidence and decisions, reports, sanctions, strikes and the NID blacklist.	M	I
DR-09	Staff accounts, parameter versions, feature-switch history, revenue log and audit log.	M	I
DR-10	Histories of escrow, KYC status, listing status, dispute status and the audit log shall be append-only. Settlement records shall satisfy the balance rule in FR-PAY-14.	M	T

7.2 Data Classification

Class	Examples	Handling
Public	Active listings, display names, ratings, masked bid history	May be shown to guests.
Internal	Order status, aggregate statistics, parameter values	Signed-in parties and staff with a need.
Confidential	Mobile numbers, e-mail, addresses, chat, transaction history, payout accounts, dispute evidence	Owner and counterparty only as needed; staff only through a case; masked in staff views and logs (SEC-ACC-05, SEC-DAT-07).
Restricted	KYC images and selfies, NID numbers, password hashes, OTP and token hashes, game-account ciphertext, encryption keys	Encrypted at rest; access logged; never in logs or exports to third parties; stored in Bangladesh in production (C-8).

7.3 Retention

Table 7.2: Retention schedule. Periods marked "to be confirmed" depend on legal review (Appendix E).

Data	Retention
KYC images and selfie	Until 30 days after account closure or rejection without resubmission, unless held for an open dispute, fraud investigation or legal request.
NID number (encrypted)	As KYC images.
NID blind index on the blacklist	While the blacklist entry exists.
Game-account ciphertext	Deleted when the order reaches a terminal state with no open dispute (FR-GAM-19).
Credential-access log	2 years after the order closes.
Settlement records, refunds, payouts, revenue log	6 years (to be confirmed against accounting and tax law).
Audit and security logs	At least CP-40; entries relating to money as for settlement records.
Chat messages	1 year after the last message, or longer while part of an open dispute or report.
Dispute case files	2 years after the decision.
Account data after closure	Deleted or anonymised within CP-41, except as above.

8 Business Rules and Configurable Parameters

8.1 Configurable Parameters

Each parameter is changed only by an administrator (FR-OPS-03), is versioned, applies to items created after the change (FR-OPS-08), and must satisfy the stated rule (FR-OPS-09). Defaults for fees and limits are initial values for the academic deliverable and are to be confirmed by the team.

Table 8.1: Configurable parameters.

ID	Parameter	Default	Rule
CP-01	Access-token lifetime	15 minutes	5–30 min
CP-02	Refresh session idle / absolute limit	7 days / 30 days	idle $\leq$ absolute
CP-03	Staff session idle / absolute limit	15 minutes / 8 hours	idle $\leq$ 30 min
CP-04	Failed sign-in threshold	5 per account per 15 min; 50 per source address per 15 min	—
CP-05	OTP validity, attempts, sends	5 min; 5 attempts; 3 sends per number per hour, 10 per day	validity $\leq$ 10 min
CP-06	Password-reset link / e-mail verification link validity	30 minutes / 24 hours	reset $\leq$ 60 min
CP-07	Auction durations offered	1, 2, 6, 24, 72 hours	max 72 h
CP-08	Minimum bid increment	Greater of 2% of current price and BDT 50, rounded up to whole taka	> 0
CP-09	Anti-sniping window / extension	2 minutes / 2 minutes	both > 0
CP-10	Auction winner's payment window	24 hours	1–72 h
CP-11	Second-chance offer: accept and pay within	24 hours	1–72 h
CP-12	Non-payment strikes	2 strikes in 90 days suspend bidding for 30 days	≥ 1
CP-13	Fixed-price checkout hold	15 minutes	5–60 min
CP-14	Self-pickup distance threshold	2 km	> 0
CP-15	Meetup handover deadline	7 days after payment	—
CP-16	Courier pickup deadline	3 days after payment	—
CP-17	Courier delivery limit before a non-delivery dispute is allowed	7 days after pickup	—
CP-18	Dispute window (physical items)	3 days after the delivery event	$<$ CP-19

ID	Parameter	Default	Rule
CP-19	Auto-release timeout (physical items)	5 days after the delivery event	> CP-18
CP-20	Seller's dispute response window	48 hours	—
CP-21	Operator dispute decision target	5 days after the seller's response or its deadline	—
CP-22	Game-account credential delivery deadline	24 hours after payment	—
CP-23	Takeover window	24 hours after the credentials are delivered	—
CP-24	Protection period	7 days after takeover	≥ 3 days
CP-25	Commission (standard / Pro Seller)	5% / 3% of item price (to be confirmed)	Pro ≤ standard
CP-26	Delivery margin	10% of delivery fee	0–50%
CP-27	Order value limits	First 30 days after verification: BDT 50,000 per order, BDT 100,000 in open orders. Then BDT 200,000 per order.	—
CP-28	Active listing limit (standard / Pro)	10 / 50	Pro ≥ standard
CP-29	Payout account cooling-off	24 hours	≥ 12 h
CP-30	Actions requiring four-eyes approval	KYC revocation; NID blacklisting and removal; dispute outcomes of BDT 20,000 or more; lifting an account suspension; staff MFA reset; emergency controls (SEC-IRM-04)	list may only grow
CP-31	Signed-URL lifetime	5 minutes	≤ 15 min
CP-32	Webhook timestamp tolerance / event-ID retention	5 minutes / 30 days	—
CP-33	Upload limits	10 MB per image; 10 photos per listing; 10 evidence files per dispute	—
CP-34	KYC resubmission limit	3 per 30 days	≥ 1
CP-35	Rate limits	Bids: 10 per minute per user per auction. Chat: 30 messages per minute. Listing creation: 10 per day. Reports: 20 per day. Search: 60 per minute per source address.	—
CP-36	Game-account feature switch	On	—
CP-37	Featured listing periods and fees	24 h or 48 h; flat fee (to be set)	—
CP-38	Notification lead times	Auction ending: 5 minutes. Deadline reminders: 24 hours and 2 hours before.	—
CP-39	Rating window / edit period	14 days after the order closes / 48 hours after posting	—
CP-40	Security-log retention	1 year	≥ 1 year
CP-41	Erasure after account closure	30 days	≤ 30 days
CP-42	Vulnerability fix targets	Critical: 7 days. High: 30 days.	—
CP-43	Courier fare table	Base fare by weight class and zone (inside Dhaka, Dhaka suburbs, outside Dhaka), from published rate cards [R14]	maintained by administrator
CP-44	KYC review target	48 hours	—

ID	Parameter	Default	Rule
CP-45	Handover-code wrong-entry limit	5	3–10
CP-46	Reconciliation interval	15 minutes	$\leq$ 60 min
CP-47	Seller strikes before automatic selling suspension	3 in 90 days	$\geq$ 1

8.2 Settlement Example

The following worked example fixes the fee arithmetic of FR-PAY-13, FR-PAY-14, FR-MON-01 and FR-DLV-13, and is to be used as a test case. A standard seller sells an item for BDT 10,000 with courier delivery at BDT 150. Commission is 5% and delivery margin is 10%.

Line	BDT
Collected from buyer	10,150.00
Platform commission (5% of 10,000)	500.00
Platform delivery margin (10% of 150)	15.00
Courier payout (150 − 15)	135.00
Seller payout (10,000 − 500)	9,500.00
Check: 500 + 15 + 135 + 9,500	10,150.00

With a partial refund of BDT 2,000 decided after delivery: the refund is taken from the item price; the commission is 5% of the BDT 8,000 released, which is BDT 400; the seller receives BDT 7,600; and the delivery fee is not refunded because the courier had delivered. The parts then total 2,000 + 400 + 15 + 135 + 7,600 = 10,150.

8.3 Revenue Streams

Stream	Charged when	Rule	Pri
Transaction commission	Payment released to seller	FR-MON-01; only on the amount released	M
Delivery margin	Courier order delivered	FR-MON-03	S
Featured listing	Seller opts in	FR-MON-05; flat fee, always labelled	C
Pro Seller subscription	Monthly, opt-in	FR-MON-06	C
Buyer-protection add-on	—	Withdrawn: every buyer has the same protection	W
Listing fees, pay-per-click	—	Not charged (FR-MON-04)	W

A Acceptance Criteria

These are the six acceptance criteria of the Project Proposal (Section 2.3), stated as testable properties. Each must hold under the reference load (NFR-PERF-01) and is verified by an automated test (NFR-MNT-02).

AC	Property	Requirements
1	Two simultaneous bids on the same auction never both register as the winning bid.	FR-AUC-03, FR-AUC-04, NFR-PERF-08
2	Two simultaneous buyers can never both purchase the last unit of a fixed-price listing.	FR-FIX-02, FR-FIX-05
3	An escrow payment is never released to a seller except by buyer confirmation after the delivery event, a genuine timeout counted from that event, or an operator's dispute decision.	FR-PAY-06, FR-PAY-07, FR-PAY-08, Table 4.8
4	A payment webhook delivered twice never results in the order being charged or settled twice.	FR-PAY-04, SEC-PAY-04, SEC-PAY-07
5	Game-account login details are never stored on the server in a form the server or an operator can read.	FR-GAM-09, SEC-GAM-01, SEC-DAT-10
6	Payment for a game-account order is never released before the protection period ends, unless the buyer releases it early or an operator decides a dispute.	FR-GAM-16, FR-GAM-17

Criterion 3 is stated more precisely than in the proposal: the timeout runs from the delivery event, not from payment (see Appendix C, item 1).

B Traceability

B.1 Proposal Objectives to Requirements

Obj.	Objective (Proposal, Section 1.3)	Main requirements
1	Gate listing and transacting behind KYC	FR-KYC-01 to FR-KYC-10, FR-TNS-06, SEC-DAT-02, SEC-DAT-03
2	Server-authoritative auction with anti-sniping	FR-AUC-01 to FR-AUC-18, NFR-PERF-02, NFR-PERF-03, NFR-REL-01
3	Single escrow step for every payment	FR-PAY-01 to FR-PAY-19, Table 4.8, SEC-PAY
4	Distance-based meetup or courier at a system fare	FR-DLV-01 to FR-DLV-13
5	Auditable record of each payment split	FR-PAY-10, FR-PAY-13, FR-PAY-14, FR-MON-09, SEC-LOG-02
6	Game-account escrow	FR-GAM-01 to FR-GAM-20, SEC-GAM-01 to SEC-GAM-03

B.2 Supplementary Report Loopholes to Requirements

The Supplementary Report (Section 4, Table 5) identifies six loopholes on existing platforms and states how TrustBazaar closes each. The requirements below are what the system must do to keep those commitments.

Loophole	Commitment in the report	Requirements
L1 Weak identity	NID + selfie KYC before listing or buying, with an AI pre-check; a banned person cannot return with a new number	FR-KYC-01 to FR-KYC-11, FR-TNS-06
L2 No payment protection	Buyer pays into escrow; seller paid on confirmation or timeout	FR-PAY-05 to FR-PAY-08, Table 4.8
L3 Unsafe handover	Safe public meetup point or courier; no cash at the meeting	FR-DLV-03 to FR-DLV-06, FR-DLV-08 to FR-DLV-10
L4 No recourse	Dispute decided while funds are still held	FR-DSP-01 to FR-DSP-11, FR-PAY-11
L5 No accountability record	Ratings only from completed escrow deals; auditable ledger	FR-REV-01, FR-REV-02, FR-PAY-13, SEC-LOG-02
L6 No fair price discovery	Server-timed auction, proxy bids, reserve, anti-sniping, bid-fraud detection	FR-AUC-01 to FR-AUC-18
Admin deals (Section 5.2)	The system, not a person, holds money and credentials; decisions logged	FR-GAM-01 to FR-GAM-20, FR-OPS-02 to FR-OPS-07
Off-platform payment	Users warned that payments outside the platform are unprotected	FR-CHT-07, FR-DLV-05

C Corrections to Version 1.1

The review for version 2.0 found the following flaws in version 1.1. Each is listed with the requirement that now resolves it.

#	Flaw in v1.1	Resolution in v2.0
1	The auto-release timeout (FR-43) had no defined start. Read literally, money could be released to the seller for an item that was never handed over.	Timeout counted from a recorded delivery event; missed fulfilment deadlines refund the buyer (FR-PAY-07, FR-PAY-08, FR-DLV-06).
2	There was no proof of handover at a meetup, so neither party could show the item had changed hands.	One-time handover code given by the buyer after inspection (FR-DLV-06).
3	Users in `pending_review` were not blocked from listing, bidding or buying (FR-7 named only `unsubmitted` and `rejected`).	FR-KYC-07.
4	One person could hold several verified accounts, and the NID blacklist (FR-103) had no NID number to compare against.	Document number captured, uniqueness enforced through a blind index (FR-KYC-01, FR-KYC-04, SEC-DAT-03).
5	There was no age requirement.	18 or over (FR-ACC-04, FR-KYC-03).
6	Phone and e-mail were never verified; there was no password reset, MFA, sign-in throttling, session revocation or step-up for sensitive actions.	FR-ACC-02, FR-ACC-06 to FR-ACC-09; Section 5.5; SEC-AUTH-04, SEC-AUTH-08.
7	Listing type mixed item kind with sale format (`game_account` was an alternative to `auction`), so a game account could not be auctioned. The two-photo rule (FR-11) contradicted game accounts and forced a defect photo even for items without defects.	Separate item kind and sale format (FR-LST-01); photo rule for physical items only, with a no-defects declaration (FR-LST-02).
8	FR-16 contradicted itself: price editable “before any bid” but not “once active”.	FR-LST-07.
9	There was no prohibited-items policy.	FR-LST-10, FR-LST-11.
10	A seller was not forbidden from bidding on their own auction (shill bidding). There was no proxy tie rule, no rule on bid retraction, and no consequence for a winner who never pays.	FR-AUC-02, FR-AUC-07, FR-AUC-10, FR-AUC-16, FR-AUC-18.
11	Bid history could identify bidders to the seller, inviting off-platform deals.	Masked bidders (FR-AUC-13).
12	Fixed-price stock was not returned when payment was abandoned. FR-38 (“queue and process in order”) was untestable and conflicted with the atomic decrement.	Checkout hold with expiry (FR-FIX-03); definite response per request (FR-FIX-05).
13	Seller payouts had no destination, ownership check or protection against account takeover.	FR-PAY-17 to FR-PAY-19.

#	Flaw in v1.1	Resolution in v2.0
14	Webhook amount and currency were not checked against the order; webhook replay was not prevented.	FR-PAY-03, SEC-PAY-04.
15	Effect of a partial refund on commission, delivery fee and ledger was undefined; refunds had no ledger entries; rounding was unspecified.	FR-PAY-11, FR-PAY-12, FR-PAY-14; worked example in Chapter 8.
16	Escrow states could change in any order.	Permitted transitions only (Table 4.8, FR-PAY-06).
17	The courier fare depended on weight, but weight was never captured. Buyer choice under and over the distance threshold was undefined. There was no pickup deadline and no handling of returned parcels.	FR-LST-03, FR-DLV-02, FR-DLV-11, FR-DLV-12.
18	Sellers had no right to respond in a dispute; there was no return-for-refund outcome, no withdrawal rule, and no rule against disputes after release.	FR-DSP-04, FR-DSP-06, FR-DSP-10, FR-DSP-11.
19	The operator's scope was contradictory: constraints said KYC and disputes only, FR-91 added reports, FR-93 added ownership proofs and FR-103 added suspension. No role could create operator accounts. There was no four-eyes control, and an operator could decide their own case.	Exhaustive action lists for operator and the new administrator role (FR-OPS-01 to FR-OPS-06).
20	Game accounts: a buyer who lost the browser key could never decrypt; a buyer's silence after 24 hours and a seller who never delivered were undefined; ciphertext was kept forever; the limit of the protection was not stated.	FR-GAM-12, FR-GAM-15, FR-GAM-10, FR-GAM-19, AS-6.
21	Chat had no warning against off-platform payment (the main scam pattern in the Supplementary Report), no blocking, and uploaded photos could leak GPS location through EXIF data.	FR-CHT-07, FR-CHT-08, SEC-DAT-08.
22	"Normal load" in the performance requirements was undefined, so they could not be tested.	Reference load NFR-PERF-01; p95 targets.
23	NFR-11 allowed auction state to be kept in Redis alone, so a cache loss could lose an end time.	NFR-REL-01, NFR-REL-02.
24	Scheduled releases and deadlines did not say what happens if the system is down when they fall due.	NFR-REL-03.
25	Parameter changes could alter the rules of orders already in progress.	FR-OPS-08, FR-OPS-09.
26	The legal references were out of date (a "draft" data protection act). There was no PCI scope statement, and nothing said that production escrow needs a licensed provider.	PDPO 2025 and Cyber Security Ordinance 2025 [R10, R11]; SEC-PAY-01; C-7, C-8.
27	The "buyer protection add-on" revenue stream had no requirement and contradicted equal protection for every buyer.	Withdrawn (W), Chapter 8.

#	Flaw in v1.1	Resolution in v2.0
28	The Pro Seller commission (FR-79) was Must Have while the Pro Seller tier was Could Have. Delivery margin was Must Have while courier delivery was Should Have.	Priorities aligned (FR-MON-02, FR-MON-03).
29	Requirements were duplicated: FR-47/NFR-10, FR-48/NFR-9, FR-88/NFR-7 and FR-46/FR-58.	Merged (Appendix D).
30	Requirements had no individual priority or verification method, and feature ranges in Chapter 3 differed from the repository README.	Pri and Ver columns; one area per backend module.
31	Notification channels were unspecified, and notifications could carry sensitive data.	FR-NTF-05, FR-NTF-06, FR-NTF-08.
32	Design content was mixed into the requirements: architecture, bid-sequence and settlement diagrams, and entity field lists.	Removed; to be specified in the SDD. Data needs stated at requirement level in Chapter 7.
33	There was no privacy notice, consent record, data export or retention schedule.	FR-PRV-01 to FR-PRV-06; Table 7.2.
34	Security requirements covered only six concerns (KYC encryption, IDOR, webhook signatures, rate limiting, secrets and the Docker setup).	Chapter 5, with an ASVS 5.0 Level 2 baseline.
35	FR-2 allowed bcrypt, which silently ignores input beyond 72 bytes. Long passphrases, especially in Bangla (3 bytes per character), would be truncated.	Argon2id required (SEC-AUTH-03).

D Mapping of Version 1.1 Identifiers

The Proposal, the repository README and the Supplementary Report refer to version 1.1 numbers (for example “FR-23 to FR-34” for the auction engine). This table gives the version 2.0 identifier for each.

v1.1	v2.0	v1.1	v2.0
FR-1	FR-ACC-01	FR-64	FR-CHT-06
FR-2	SEC-AUTH-01, SEC-AUTH-03	FR-65	FR-REV-01
FR-3	FR-ACC-05, SEC-SES-01, SEC-SES-02	FR-66	FR-REV-02
FR-4	FR-KYC-01	FR-67	FR-REV-04
FR-5	SEC-ACC-06, SEC-DAT-02	FR-68	FR-REV-05
FR-6	FR-KYC-05, FR-KYC-06	FR-69	FR-DSP-01
FR-7	FR-KYC-07	FR-70	FR-DSP-02
FR-8	FR-KYC-08	FR-71	FR-DSP-03
FR-9	FR-KYC-09	FR-72	FR-DSP-06, FR-DSP-07
FR-10	FR-LST-01, FR-LST-02	FR-73	FR-DSP-09
FR-11	FR-LST-02	FR-74	FR-NTF-01
FR-12	FR-LST-01	FR-75	FR-NTF-02
FR-13	FR-LST-04	FR-76	FR-NTF-03
FR-14	FR-LST-05	FR-77	FR-NTF-04
FR-15	FR-LST-06	FR-78	FR-MON-01
FR-16	FR-LST-07	FR-79	FR-MON-02
FR-17	FR-LST-08	FR-80	FR-MON-03
FR-18	FR-LST-09	FR-81	FR-MON-05
FR-19	FR-SRC-01	FR-82	FR-MON-05
FR-20	FR-SRC-02	FR-83	FR-MON-06
FR-21	FR-SRC-03	FR-84	FR-MON-07
FR-22	FR-SRC-04	FR-85	FR-MON-08
FR-23	FR-AUC-01	FR-86	FR-MON-09
FR-24	FR-AUC-02	FR-87	FR-TNS-01
FR-25	FR-AUC-03	FR-88	FR-AUC-17, SEC-ABU-01
FR-26	FR-AUC-04	FR-89	FR-TNS-02
FR-27	FR-AUC-05	FR-90	SEC-LOG-01, SEC-LOG-02
FR-28	FR-AUC-06	FR-91	FR-OPS-01, FR-OPS-02
FR-29	FR-AUC-08	FR-92	FR-GAM-02
FR-30	FR-AUC-09	FR-93	FR-GAM-03
FR-31	FR-AUC-11	FR-94	FR-GAM-04
FR-32	FR-AUC-12	FR-95	FR-GAM-05
FR-33	FR-AUC-14	FR-96	FR-GAM-07
FR-34	FR-AUC-15	FR-97	FR-GAM-09
FR-35	FR-FIX-01	FR-98	FR-GAM-10, FR-GAM-11
FR-36	FR-FIX-02	FR-99	FR-GAM-13
FR-37	FR-FIX-04	FR-100	FR-GAM-14
FR-38	FR-FIX-05	FR-101	FR-GAM-16

v1.1	v2.0	v1.1	v2.0
FR-39	FR-PAY-01	FR-102	FR-GAM-17
FR-40	FR-PAY-02	FR-103	FR-GAM-18
FR-41	FR-PAY-04	NFR-1	NFR-PERF-02
FR-42	FR-PAY-05	NFR-2	NFR-PERF-03
FR-43	FR-PAY-07	NFR-3	NFR-PERF-05
FR-44	FR-PAY-06, FR-PAY-10	NFR-4	SEC-DAT-02, SEC-DAT-04
FR-45	FR-PAY-11	NFR-5	SEC-ACC-02
FR-46	FR-PAY-13	NFR-6	SEC-PAY-03
FR-47	FR-PAY-15	NFR-7	SEC-AUTH-04, SEC-ABU-01
FR-48	FR-PAY-16	NFR-8	SEC-DAT-05, SEC-SDL-05
FR-49	SEC-PAY-01, SEC-PAY-02	NFR-9	FR-PAY-16
FR-50	FR-DLV-01	NFR-10	FR-PAY-15
FR-51	FR-DLV-02	NFR-11	NFR-REL-01
FR-52	FR-DLV-03, FR-DLV-05	NFR-12	NFR-USE-01
FR-53	FR-DLV-07	NFR-13	NFR-USE-02
FR-54	FR-DLV-08	NFR-14	NFR-MNT-01
FR-55	FR-DLV-09	NFR-15	NFR-MNT-02
FR-56	FR-DLV-10	NFR-16	SEC-SDL-02
FR-57	FR-DLV-10	NFR-17	FR-PRV-04, NFR-CMP-01
FR-58	FR-DLV-13	NFR-18	FR-MON-10
FR-59	FR-CHT-01	NFR-19	NFR-SCL-01
FR-60	FR-CHT-02	NFR-20	NFR-SCL-02, NFR-SCL-03
FR-61	FR-CHT-03	NFR-21	SEC-GAM-01
FR-62	FR-CHT-04	NFR-22	SEC-GAM-02
FR-63	FR-CHT-05	NFR-23	NFR-USE-03

E Open Issues

OI-1 Fee levels. The commission rates (CP-25), delivery margin (CP-26) and featured-listing fees (CP-37) are placeholders until the team agrees them.

OI-2 Retention periods. The six-year period for financial records and the periods for KYC data (Table 7.2) are to be confirmed against Bangladeshi accounting, tax and anti-money-laundering rules and the PDPO, including any rules made under it.

OI-3 PDPO detail. The PDPO was gazetted on 6 November 2025, with a compliance window reported as 18 months. The deadline for breach notification and the data-localisation categories are to be confirmed from the official text before production use.

OI-4 Payouts in sandbox. Whether bKash or Nagad sandboxes offer disbursement (payout) APIs to the project is not yet known; until then payouts are simulated (FR-PAY-19).

OI-5 Courier sandbox. Availability of Pathao or Steadfast sandbox access is not yet known; the mock courier is the default (C-3).

OI-6 Liveness check. Whether the basic randomized-action check (FR-KYC-02) is reviewed manually by the operator or by the optional pre-check service (FR-KYC-11) is to be decided in design.

OI-7 Game-account legality. Trading accounts conflicts with most publishers' terms (Supplementary Report, Section 5.2). Legal advice is needed before any production launch of the game-account feature, which is why it can be switched off (CP-36).